



U.S. Department of Justice
Federal Bureau of Prisons
Field Acquisition Office

*U.S. Armed Forces Reserve Complex
Grand Prairie, Texas 75051*

July 10, 2026

RE: Request for Quote (RFQ) 15BCMS26Q70000005
Historical Medical Claims Data Analysis

Dear Quoter:

Accompanying this cover letter is a solicitation package prepared by the Federal Bureau of Prisons, Field Acquisition Office, for the acquisition of Historical Medical Claims Analysis. The solicitation package consists of the following:

Cover Letter
Request for Quotation
Attachments

In submitting quotes, quoters should consider all information provided herein. Please carefully follow all instructions located in the solicitation package concerning the content, format, and submission of the quotes.

System updates may lag policy updates. The System for Award Management (SAM) may continue to require entities to complete representations based on provisions that are not included in this solicitation. Contracting officers will rely on representations from quotes based on provisions in the solicitation. Entities are not required to, nor are they able to, update their entity registration to remove these representations in SAM.

Funds are not presently available for this solicitation. No award will be made under this solicitation until funds are made available and confirmed in writing by the contracting officer. The Government reserves the right to cancel this solicitation at any time, either before or after the closing date. In the event of cancellation, the Government shall have no obligation to reimburse any responding party for any costs incurred in connection with the preparation or submission of its quote.

All communication regarding this RFQ, including any of a technical nature, must be made in writing to the Contracting Officer (CO). Questions will not be answered by telephone or in person. Please read the important instructions that are incorporated by reference in the provision at FAR Deviation 52.212-1, Instructions to Offerors – Commercial Products and Commercial

Services, and any addendum.

The CO assigned to this procurement is the undersigned. Your attention is directed to the fact that the CO is the only individual who can legally commit or obligate the Government to an expenditure of public funds should a contract result from this RFQ.

Prospective Quoters are also cautioned against discussing the preparation of their quote (or any technical questions) with Government technical personnel. The circumstances of such contact, when verified, may result in non-consideration of the quote. Accordingly, all communication prior to award shall be directed to the CO, in writing, at the email address listed below.

You may e-mail any questions to kmfisher@bop.gov and jhamblin@bop.gov. We will consider all questions received and provide responses where appropriate.

Sincerely,

Contracting Officer

19. ITEM NUMBER	20. SCHEDULE OF SUPPLIES/SERVICES	21. QUANTITY	22. UNIT	23. UNIT PRICE	24. AMOUNT

32a. QUANTITY IN COLUMN 21 HAS BEEN

☐ RECEIVED ☐ INSPECTED ☐ ACCEPTED, AND CONFORMS TO THE CONTRACT, EXCEPT AS NOTED: _____

32b. SIGNATURE OF AUTHORIZED GOVERNMENT REPRESENTATIVE	32c. DATE	32d. PRINTED NAME AND TITLE OF AUTHORIZED GOVERNMENT REPRESENTATIVE

32e. MAILING ADDRESS OF AUTHORIZED GOVERNMENT REPRESENTATIVE	32f. TELEPHONE NUMBER OF AUTHORIZED GOVERNMENT REPRESENTATIVE
	32g. E-MAIL OF AUTHORIZED GOVERNMENT REPRESENTATIVE

33. SHIP NUMBER	34. VOUCHER NUMBER	35. AMOUNT VERIFIED CORRECT FOR	36. PAYMENT ☐ COMPLETE ☐ PARTIAL ☐ FINAL	37. CHECK NUMBER
☐ PARTIAL ☐ FINAL				
38. S/R ACCOUNT NUMBER	39. S/R VOUCHER NUMBER	40. PAID BY		

41a. I CERTIFY THIS ACCOUNT IS CORRECT AND PROPER FOR PAYMENT	42a. RECEIVED BY (<i>Print</i>)
41b. SIGNATURE AND TITLE OF CERTIFYING OFFICER	42b. RECEIVED AT (<i>Location</i>)
41c. DATE	42c. DATE REC'D (YY/MM/DD)
	42d. TOTAL CONTAINERS

Table of Contents

<u>Section</u>	<u>Description</u>	<u>Page Number</u>
1	Solicitation/Contract Form.....	1
	Commodity or Services Schedule	4
	1.1 Statement of Work	4
	1.2 Packaging and Marking.....	4
	1.3 Inspection and Acceptance	4
	1.4 Deliveries and Performance.....	4
	1.5 Special Contract Requirements.....	4
2	Contract Clauses	5
	2852.212-4 Contract Terms and Conditions, Commercial Items (FAR Deviation) (NOV 2020).....	5
	52.204-13 (DEV) System for Award Management-Maintenance (Oct 2018) (DEVIATION NOV 2025).....	8
	52.212-4 (DEV) Terms and Conditions-Commercial Products and Commercial Services (Nov 2023) (DEVIATION NOV 2025).....	8
	52.219-6 (DEV) Notice of Total Small Business Set-Aside (Nov 2020) (DEVIATION DEC 2025).....	8
	52.219-14 (DEV) Limitations on Subcontracting (Oct 2022) (DEVIATION DEC 2025).....	9
	52.222-90 Addressing DEI Discrimination by Federal Contractors (APR 2026).....	9
	52.226-8 Encouraging Contractor Policies To Ban Text Messaging While Driving (May 2024).....	9
	52.232-40 Providing Accelerated Payments to Small Business Subcontractors (Mar 2023).....	9
	52.240-93 (DEV) Basic Safeguarding of Covered Contractor Information Systems (DEVIATION NOV 2025).....	9
	52.240-91 (DEV) Security Prohibitions and Exclusions (DEVIATION NOV 2025)	9
	2852.201-70 Contracting Officer's Representative (COR) (NOV 2020).....	17
	2852.223-70 Unsafe Conditions Due to the Presence of Hazardous Material (NOV 2020).....	17
	DOJ-01 Whistleblower Information Distribution (Oct 2021)	18
	DOJ-02 Contractor Privacy Requirements (JAN 2022)	18
	DOJ-03 Personnel Security Requirements For Contractor Employees (Nov 2021)	23
	DOJ-05 Security of Department Information and Systems (APR 2026).....	28
	DOJ-07 Prohibition On Access By Non-U.S. Citizens To DOJ IT Systems (MAR 2002).....	35
	DOJ-08 Continuing Contract Performance During a Pandemic Influenza or other National Emergency (OCT 2007).....	35
	DOJ-09 Large Language Models (MAR 2026).....	36
3	List of Attachments	38
4	Solicitation Provisions	39
	52.204-7 (DEV) System for Award Management-Registration (Nov 2024) (DEVIATION NOV 2025).....	39
	52.212-1 (DEV) Instructions to Offerors-Commercial Products and Commercial Services (Sep 2023) (DEVIATION NOV 2025)	39
	52.212-2 (DEV) Evaluation-Commercial Products and Commercial Services (Nov 2021) (DEVIATION NOV 2025)	39
	52.240-90 (DEV) Security Prohibitions and Exclusions Representations and Certifications (DEVIATION NOV 2025).....	39
	2852.233-70 Protests Filed Directly with the Department of Justice (NOV 2020)	39
	4.1 Instructions to Quoters.....	40
	4.2 Evaluation Factors for Award.....	41

Section 1 - Commodity or Services Schedule**SCHEDULE OF SUPPLIES/SERVICES**

CONTINUATION SHEET

ITEM NO.	SUPPLIES/SERVICES	QUANTITY	UNIT	UNIT PRICE	AMOUNT
0001	Historical medical claims data analysis per the statement of work. PSC: R405	1	JB	\$ _____	\$ _____

1.1 Statement of Work

See attached

1.2 Packaging and Marking

All deliverables shall be submitted electronically in searchable PDF and Microsoft Excel, Word, or other Government-approved editable formats. Each deliverable shall identify the purchase order number, contractor name, and delivery date.

1.3 Inspection and Acceptance

Inspection shall be performed by the Contracting Officer's Representative (COR). Acceptance shall occur after the Government determines that all contractual requirements have been satisfied. The Government may require correction of deficient deliverables at no additional cost.

1.4 Deliveries and Performance

Performance begins upon receipt of Government-furnished information. Final deliverables are due within 60 calendar days after receipt of the complete claims dataset unless modified by the Contracting Officer. Deliverables shall be transmitted electronically unless otherwise directed.

1.5 Special Contract Requirements

The Contractor may use commercial AI tools identified in its quotation. The Contractor remains solely responsible for the accuracy of all deliverables. All Government-furnished information remains Government property. Government data shall not be used to train, fine tune, or improve commercial AI models or shared with publicly accessible AI services. All AI-assisted analytical conclusions shall undergo human review prior to submission. Contractor shall safeguard Government information consistent with applicable contract clauses. Contractor shall safeguard Government information consistent with applicable contract clauses. All reports, spreadsheets, analyses, visualizations, and supporting documentation become Government property upon acceptance. All reports, spreadsheets, analyses, visualizations, and supporting documentation become Government property upon acceptance.

Section 2 - Contract Clauses

2852.212-4 Contract Terms and Conditions, Commercial Items (FAR Deviation) (NOV 2020)

When a commercial item is contemplated (using FAR part 12 procedures or otherwise) and the contract will include FAR 52.212-4, the following replaces subparagraph (g)(2); paragraph (h); subparagraph (i)(2); paragraph (s); and paragraph (u), Unauthorized Obligations, of the basic FAR clause, and adds paragraph (w), as follows:

(g)(2) Invoices will be handled in accordance with the Prompt Payment Act (31 U.S.C. 3903) and Office of Management and Budget (OMB) prompt payment act regulations at 5 CFR part 1315, as modified by subparagraph (i)(2), *Prompt payment*, of this clause.

(h) *Patent indemnity*. Contractor shall indemnify and hold harmless the Government and its respective affiliates, officers, directors, employees, agents, successors and assigns (collectively, "Indemnities") from and against any and all liability and losses incurred by the Indemnities that are (i) included in any settlement and/or (ii) awarded by a court of competent jurisdiction arising from or in connection with any third party claim of infringement made against Indemnities asserting that any product or service supplied under this contract constitutes infringement of any patent, copyright, trademark, service mark, trade name or other proprietary or intellectual right. This indemnity shall not apply unless Contractor shall have been informed within a reasonable time by the Government of the claim or action alleging such infringement and shall have been given such opportunity as is afforded by applicable laws, rules, or regulations to participate in its defense. This indemnity also shall not apply to any claim unreasonably settled by the Government which obligates Contractor to make any admission or pay any amount without written consent signed by an authorized officer of Contractor, unless required by final decree of a court of competent jurisdiction.

(i)(2) *Prompt payment*. The Government will make payment in accordance with the Prompt Payment Act (31 U.S.C. 3903) and prompt payment regulations (5 CFR part 1315), with the following modification regarding the due date: For the sole purpose of computing an interest penalty due the Contractor, the Government agrees to inspect and determine the acceptability of any supply delivered or service performed specified in the invoice within thirty (30) days of receipt of a proper invoice from the Contractor, after which time, if no affirmative action has been taken by the Government to accept such supply or service, the supply or service will be deemed accepted and payment due thirty (30) days from the date of deemed acceptance. If the Government makes the determination that the item delivered or service performed is deficient or otherwise unacceptable, or the invoice is otherwise determined not to be a proper invoice, the terms and conditions of this paragraph regarding prompt payment will apply to the date the Contractor corrects the deficiency in the item delivered or service performed or submits a proper invoice. If actual acceptance occurs within the constructive acceptance period, the Government will base the determination of an interest penalty on the actual date of acceptance. The constructive acceptance requirement does not, however, compel Government officials to accept supplies or services, perform contract administration functions, or make payment prior to fulfilling their responsibilities.

(s) *Order of precedence*. Any inconsistencies in this solicitation or contract shall be resolved by giving precedence in the following order:

- (1) The schedule of supplies/services.
- (2) The Assignments, Payments, Invoice, Other Compliances, and Compliance with Laws Unique to Government Contracts provisions of the basic FAR clause at 52.212-4, and the Unauthorized Obligations and Contractor's Commercial Supplier Agreements—Unenforceable Clauses provisions of JAR 2852.212-4.
- (3) FAR 52.212-5.
- (4) Other paragraphs of the basic FAR clause at 52.212-4, with the exception of paragraph (o), Warranty, and those paragraphs identified in this deviation of 52.212-4.
- (5) Addenda to this solicitation, contract, or order, including contractor's Commercial supplier agreements incorporated into the contract.
- (6) Solicitation provisions if this is a solicitation.
- (7) Paragraph (o), Warranty, of the basic FAR clause at 52.212-4.
- (8) The Standard Form 1449.
- (9) Other documents, exhibits, and attachments.
- (10) The specification.

(u) *Unauthorized obligations*.

- (1) Except as stated in paragraph (u)(2) of this clause, when any supply or service acquired under this contract or order is subject to any Commercial supplier agreement that includes any language, provision, or clause requiring the Government

to indemnify the Contractor or any person or entity for damages, costs, fees, or any other loss or liability that would create an Anti-Deficiency Act violation (see 31 U.S.C. 1341), the following shall govern:

(i) Any such language, provision, or clause is unenforceable against the Government.

(ii) Neither the Government nor any Government authorized end user shall be deemed to have agreed to such clause by virtue of it appearing in the commercial supplier agreement. If the commercial supplier agreement is invoked through an "I agree" click box or other similar mechanism (e.g., "click-wrap" or "browse-wrap" agreements), execution does not bind the Government or any Government authorized end user to such clause.

(iii) Any such language, provision, or clause is deemed to be stricken from the commercial supplier agreement and have no effect.

(2) Paragraph (u)(1) of this clause does not apply to indemnification by the Government that is expressly authorized by statute and specifically authorized under applicable agency regulations and procedures.

(w) *Commercial supplier agreements—unenforceable clauses.* When any supply or service acquired under this contract or order is subject to a contractor's commercial supplier agreement, the following shall be deemed incorporated into such agreement and modifies and replaces any similar language, provision, or clause in such agreement. As used herein, "this agreement" means any contractor commercial supplier agreement:

(1) Notwithstanding any other provision of this agreement, when the end user is an agency or instrumentality of the U.S. Government, the following shall apply:

(i) *Applicability.* This agreement is a part of a contract between commercial supplier and the U.S. Government for the acquisition of the supply or service that necessitates a license or other similar legal instrument (including all contracts, task orders, and delivery orders under FAR part 12).

(ii) *End user.* This agreement shall bind the Government as end user but shall not operate to bind the Government employee or person acting on behalf of the Government in his or her personal capacity.

(iii) *Law and disputes.* This agreement is governed by Federal law.

(A) Any language, provision, or clause purporting to subject the U.S. Government to the laws of any U.S. state, territory, district, or municipality, or the laws of a foreign nation, except where Federal law expressly provides for the application of such laws, is hereby deleted and shall have no effect.

(B) Any language, provision, or clause requiring dispute resolution in a specific forum or venue that is different from that prescribed by applicable Federal law is hereby deleted and shall have no effect.

(C) Any language, provision, or clause prescribing a different time period for bringing an action than that prescribed by applicable Federal law in relation to a dispute is hereby deleted and shall have no effect.

(iv) *Continued performance.* Notwithstanding any other provision in this agreement, if the Contractor believes the Government to be in breach of this contract, order, or agreement, it shall pursue its rights under the Contract Disputes Act or other applicable Federal statute while continuing performance as set forth in subparagraph (d), Disputes, of FAR 52.212-4.

(v) *Arbitration; equitable or injunctive relief.* In the event of a claim or dispute arising under or relating to the contract, order, or this agreement, (A) binding arbitration shall not be used unless otherwise specifically authorized by agency guidance, and (B) equitable or injunctive relief, including the award of attorney fees, costs or interest, may be awarded against the Government only when explicitly provided by statute.

(vi) *Updating terms.*

(A) After award, the contractor may unilaterally revise terms if they are not material. Material terms are defined as:

(1) Terms that change Government rights or obligations;

(2) Terms that increase Government prices;

(3) Terms that decrease the overall level of service; or

(4) Terms that limit any other Government right addressed elsewhere in this contract.

(B) For revisions that materially change the terms of the contract, the revised commercial supplier agreement must be incorporated into the contract using a bilateral modification.

(C) Any agreement terms or conditions unilaterally revised subsequent to award that are inconsistent with any material term or provisions of this contract shall not be enforceable against the Government, and the Government shall not be deemed to have consented to them.

(vii) *Order of precedence.* Any Order of Precedence clause in any commercial supplier agreement is not enforceable against the Government. The applicable Order of Precedence for this contract, order, or agreement is FAR 52.212-4(s), as revised by JAR 2812.302 and 2852.212-4(s).

(viii) *No automatic renewals.* If any license or service tied to period payment is provided under this agreement (e.g., annual software maintenance or annual lease term), such license or service shall not renew automatically upon expiration of its current term without prior express consent by a properly warranted contracting officer, and any provision or term of any license or service purporting to provide for automatic renewal is unenforceable against the Government.

(ix) *Indemnification by the Government or end-user.* Any language, provision, or clause of this commercial supplier agreement requiring the Government or End-user to indemnify the commercial supplier or licensor is not enforceable against the Government.

(x) *Indemnification by the commercial supplier or licensor.* Any clause of this agreement requiring or permitting the commercial supplier or licensor to defend the Government as a condition of indemnifying the Government for any claim of infringement is hereby amended to provide that the U.S. Department of Justice has the sole right to represent the United States in any such action, in accordance with 28 U.S.C. 516.

(xi) *Audits.* Any language, provision, or clause of this commercial supplier agreement permitting Contractor to audit the end user's compliance with this agreement is not enforceable against the Government. To the extent any language, provision or clause of this agreement permits Contractor to audit the Government's compliance under this contract, order, or agreement, such language, provision, or clause of this agreement is hereby stricken and replaced as follows:

"(A) If Contractor reasonably believes that the Government has violated the terms of this agreement with regard to the restrictions on authorized use and/or the number of authorized users, upon written request from Contractor, including an explanation of the basis for the request, DOJ will provide a redacted version of the Government's most recent Security Assessment and Authorization package (SAA) to Contractor on a confidential basis, so that Contractor may reasonably verify the Government's compliance with its obligations under this agreement. Contractor understands and agrees that the Government will remove or redact any information from the SAA that it reasonably believes may compromise (a) the security of the Government's information technology environment; (b) the confidentiality of any third-party proprietary or confidential information; (c) any confidential, sensitive law enforcement information; and (d) any other information that the Government believes may compromise a past, current, or prospective investigation, prosecution, or litigation. Notwithstanding the preceding, and subject to the Government's policies and procedures for such review, including but not limited to complying with all Government security requirements prior to being granted access to the Government's facilities, including the execution of appropriate confidentiality and/or non-disclosure agreements, the Government will arrange, upon Contractor's written request, for Contractor to view an un-redacted version of the SAA on Government premises. Contractor understands that Contractor will be provided a copy of the un-redacted SAA on Government premises only and that no un-redacted copy of the SAA, or any medium containing information relating to it, will be permitted to be removed from Government premises.

(B) The Contractor also understands and agrees that the Contractor shall make a request under this paragraph no more than on an annual basis and only during the period of the contract, and that any activities performed by Contractor under this clause will be performed at Contractor's expense, without reimbursement by the Government.

(C) Discrepancies found with regard to the restrictions on authorized use and/or the number of authorized users may result in a charge by Contractor to the Government. Any resulting invoice must comply with the proper invoicing and payment requirements specified in the contract. This charge, if disputed by the Government, will be resolved through the Disputes clause at 52.212-4(d); no payment obligation shall arise on the part of the Government until the conclusion of the dispute process."

(xii) *Taxes or surcharges.* Any taxes or surcharges which the Contractor seeks to pass along to the Government as end user will be governed by the terms of the underlying Government contract and, in any event, must be submitted to the Contracting Officer for a determination of applicability prior to invoicing unless specifically agreed to otherwise in the Government contract.

(xiii) *Non-assignment.* This agreement may not be assigned, nor may any rights or obligations thereunder be delegated, without the Government's prior approval, except as expressly permitted under FAR 52.212-4 (b), Assignment.

(xiv) *Confidential information.*

(A) During the term of this contract or order, either party may identify information as "confidential information," and there shall be no disclosure, dissemination, or publication of any such information except to the extent required for the performance of this contract or order and otherwise provided in this clause or by statute or regulation. Specifically, the parties agree that the party receiving confidential information may only disclose such information to its employees and contractors on a "need-to-know" basis to carry out the obligations of this contract or order, and that subcontractors performing under this Agreement are subject to the same stipulations provided in this provision. The parties also agree that this provision shall survive the termination of this contract or order, and any confidential information obtained or received which comes within these restrictions shall remain confidential, provided that the obligation to treat information as confidential shall not apply to information which is or becomes publicly available through no improper action of the receiving party; is or comes to be in the receiving party's possession independent of its relationship with the disclosing party; is developed by or becomes known to the receiving party without use of any confidential information of the disclosing party; or is obtained rightfully from a third party not bound by an obligation of confidentiality. Additionally, nothing in this contract or order shall restrict disclosure by the receiving party pursuant to any applicable law, including but not limited to the Freedom of Information Act, 5 U.S.C. 552, *et seq.*, or an order of any court of competent jurisdiction, provided that in either such case the receiving party gives prompt notice to the disclosing party to allow the disclosing party to interpose an objection to such disclosure, take action to assure confidential handling of the confidential information, or take such other action as it deems appropriate to protect its confidential information.

(B) The Government considers and hereby identifies as confidential any and all information related to any inquiries and/or searches performed by the Government or by contractor at the Government's direction under this contract or order, including the subject of any such inquiry or search and any and all search terms, regardless of whether provided in writing or orally to Contractor, and Contractor agrees that it may only disclose such information to its employees and contractors

on a "need-to-know" basis to carry out the obligations of this contract or order and that it will not share, reveal, divulge, disclose, disseminate, or publicize any such information to any third party except as provided in this provision without the prior written approval of the Contracting Officer. Contractor also understands and agrees that any subcontractors performing under this contract or order are subject to the same stipulations and that Contractor may be held responsible for any violations of confidentiality by a subcontractor.

(C) These provisions are consistent with and do not supersede, conflict with, or otherwise alter an employee's obligations, rights, or liabilities created by existing statute or Executive order relating to (1) classified information, (2) communications to Congress, (3) the reporting to an Inspector General of a violation of any law, rule, or regulation, or mismanagement, a gross waste of funds, an abuse of authority, or a substantial and specific danger to public health or safety, or (4) any other whistleblower protection. The definitions, requirements, obligations, rights, sanctions, and liabilities created by Executive orders and statutory provisions relating to whistleblower protection are incorporated into this contract and are controlling.

(D) The Government may share the terms, conditions and prices set forth in this Order with, and provide a copy of the Order to, other Executive branch agencies of the U.S. Government, provided that the Government shall ensure that other Executive branch agencies to which it provides such information will be required to treat all such information consistent with terms and conditions set forth in this Order.

(E) Notwithstanding anything in this agreement, the Government may retain any confidential information as required by law, regulation, or its internal document retention procedures for legal, regulatory, or compliance purposes; provided, however, that all such retained confidential information will continue to be subject to the confidentiality obligations of this Order.

(xv) *Authorized users.* Authorized users may include full and part-time employees of the Government, including those working at or from remote locations, and contractors and contractor employees working within the scope of their contract with the Government, including those at or from remote locations.

(xvi) *Authorized use.* Authorized users are authorized to use the product or service acquired under this contract in performing business on behalf of the Government. Any information obtained or acquired by the Government under this contract may be used by the Government in the performance of Government business.

(2) If any language, provision, or clause of this agreement conflicts or is inconsistent with the preceding paragraph (w)(1), the language, provisions, or clause of paragraph (w)(1) shall prevail to the extent of such inconsistency.

A.1 ADDENDUM TO FAR 52.212-4, Contract Terms and Conditions, Commercial Items (FAR Deviation) (NOV 2020)

The terms and conditions for the following clauses are hereby incorporated into this solicitation and resulting contract as an addendum to FAR clause 52.212-4.

Clauses By Reference

52.252-2 CLAUSES INCORPORATED BY REFERENCE (FEB 1998)

This contract incorporates one or more clauses by reference, with the same force and effect as if they were given in full text. Upon request, the Contracting Officer will make their full text available. Also, the full text of a clause may be accessed electronically at this/these address(es): www.acquisition.gov

Clause	Title	Fill-ins (if applicable)
52.204-13 (DEV)	System for Award Management-Maintenance (Oct 2018) (DEVIATION NOV 2025)	
52.212-4 (DEV)	Terms and Conditions-Commercial Products and Commercial Services (Nov 2023) (DEVIATION NOV 2025)	

Clause	Title	Fill-ins (if applicable)
52.219-6 (DEV)	Notice of Total Small Business Set-Aside (Nov 2020) (DEVIATION DEC 2025)	
52.219-14 (DEV)	Limitations on Subcontracting (Oct 2022) (DEVIATION DEC 2025)	(f)(1) End of Base Term: "X"
52.222-90	Addressing DEI Discrimination by Federal Contractors (APR 2026)	
52.226-8	Encouraging Contractor Policies To Ban Text Messaging While Driving (May 2024)	
52.232-40	Providing Accelerated Payments to Small Business Subcontractors (Mar 2023)	
52.240-93 (DEV)	Basic Safeguarding of Covered Contractor Information Systems (DEVIATION NOV 2025)	

Clauses By Full Text

52.240-91 (DEV) Security Prohibitions and Exclusions (DEVIATION NOV 2025)

(a) *Definitions.* As used in this clause—

American Security Drone Act-covered foreign entity means an entity included on a list that the Federal Acquisition Security Council (FASC) develops and maintains and publishes in the System for Award Management (SAM) at <https://www.sam.gov> (section 1822 of Pub. L. 118-31, 41 U.S.C. 3901 note prec.).

Backhaul means intermediate links between the core network, or backbone network, and the small subnetworks at the edge of the network (e.g., connecting cell phones/towers to the core telephone network). Backhaul can be wireless (e.g., microwave) or wired (e.g., fiber optic, coaxial cable, Ethernet).

Covered application means the social networking service TikTok or any successor application or service developed or provided by ByteDance Limited or an entity owned by ByteDance Limited.

Covered article, as defined in 41 U.S.C. 4713(k), means:

- (1) Information technology, as defined in 40 U.S.C. 11101, including cloud computing services of all types;
- (2) Telecommunications equipment or telecommunications service, as those terms are defined in section 3 of the Communications Act of 1934 (47 U.S.C. 153);
- (3) The processing of information on a Federal or non-Federal information system, subject to the requirements of the Controlled Unclassified Information program (see 32 CFR part 2002); or
- (4) Hardware, systems, devices, software, or services that include embedded or incidental information technology.

Covered foreign country means The People's Republic of China.

Covered telecommunications equipment or services means—

- (1) Telecommunications equipment produced by Huawei Technologies Company or ZTE Corporation (or any subsidiary or affiliate of such entities);
- (2) For the purpose of public safety, security of Government facilities, physical security surveillance of critical infrastructure, and other national security purposes, video surveillance and telecommunications equipment produced by Hytera Communications Corporation, Hangzhou Hikvision Digital Technology Company, or Dahua Technology Company (or any subsidiary or affiliate of such entities);
- (3) Telecommunications or video surveillance services provided by such entities or using such equipment; or
- (4) Telecommunications or video surveillance equipment or services produced or provided by an entity that the Secretary of Defense, in consultation with the Director of National Intelligence or the Director of the Federal Bureau of Investigation, reasonably believes to be an entity owned or controlled by, or otherwise connected to, the government of a covered foreign country.

Critical technology means—

- (1) Defense articles or defense services included on the United States Munitions List set forth in the International Traffic in Arms Regulations under subchapter M of chapter I of title 22, Code of Federal Regulations;
- (2) Items included on the Commerce Control List set forth in Supplement No. 1 to part 774 of the Export Administration Regulations under subchapter C of chapter VII of title 15, Code of Federal Regulations, and controlled—
 - (i) Pursuant to multilateral regimes, including for reasons relating to national security, chemical and biological weapons proliferation, nuclear nonproliferation, or missile technology; or
 - (ii) For reasons relating to regional stability or surreptitious listening;
- (3) Specially designed and prepared nuclear equipment, parts and components, materials, software, and technology covered by part 810 of title 10, Code of Federal Regulations (relating to assistance to foreign atomic energy activities);
- (4) Nuclear facilities, equipment, and material covered by part 110 of title 10, Code of Federal Regulations (relating to export and import of nuclear equipment and material);
- (5) Select agents and toxins covered by part 331 of title 7, Code of Federal Regulations, part 121 of title 9 of such Code, or part 73 of title 42 of such Code; or
- (6) Emerging and foundational technologies controlled pursuant to section 1758 of the Export Control Reform Act of 2018 (50 U.S.C. 4817).

FASC-prohibited unmanned aircraft system means an unmanned aircraft system manufactured or assembled by an American Security Drone Act—covered foreign entity.

FASCSA order means any of the following orders issued under the Federal Acquisition Supply Chain Security Act (FASCSA) requiring removing covered articles from executive agency information systems or excluding one or more named sources or named covered articles from executive agency procurement actions, as described in 41 CFR 201-1.303(d) and (e):

- (1) The Secretary of Homeland Security may issue FASCSA orders that apply to civilian agencies, to the extent not covered by paragraph (2) or (3) of this definition. This type of FASCSA order may be referred to as a Department of Homeland Security (DHS) FASCSA order.
- (2) The Secretary of Defense may issue FASCSA orders that apply to the Department of Defense (DoD) and national security systems other than sensitive compartmented information systems. This type of FASCSA order may be referred to as a DoD FASCSA order.

(3) The Director of National Intelligence (DNI) may issue FASCSA orders that apply to the intelligence community and sensitive compartmented information systems, to the extent not covered by paragraph (2) of this definition. This type of FASCSA order may be referred to as a DNI FASCSA order.

Information technology, as defined in 40 U.S.C. 11101(6)—

(1) Means any equipment or interconnected system or subsystem of equipment, used in the automatic acquisition, storage, analysis, evaluation, manipulation, management, movement, control, display, switching, interchange, transmission, or reception of data or information by the executive agency, if the equipment is used by the executive agency directly or is used by a contractor under a contract with the executive agency that requires the use—

(i) Of that equipment; or

(ii) Of that equipment to a significant extent in the performance of a service or the furnishing of a product;

(2) Includes computers, ancillary equipment (including imaging peripherals, input, output, and storage devices necessary for security and surveillance), peripheral equipment designed to be controlled by the central processing unit of a computer, software, firmware and similar procedures, services (including support services), and related resources; but

(3) Does not include any equipment acquired by a Federal contractor incidental to a Federal contract.

Intelligence community, as defined by 50 U.S.C. 3003(4), means the following—

(1) The Office of the Director of National Intelligence;

(2) The Central Intelligence Agency;

(3) The National Security Agency;

(4) The Defense Intelligence Agency;

(5) The National Geospatial-Intelligence Agency;

(6) The National Reconnaissance Office;

(7) Other offices within the Department of Defense for the collection of specialized national intelligence through reconnaissance programs;

(8) The intelligence elements of the Army, the Navy, the Air Force, the Marine Corps, the Coast Guard, the Federal Bureau of Investigation, the Drug Enforcement Administration, and the Department of Energy;

(9) The Bureau of Intelligence and Research of the Department of State;

(10) The Office of Intelligence and Analysis of the Department of the Treasury;

(11) The Office of Intelligence and Analysis of the Department of Homeland Security; or

(12) Such other elements of any department or agency as may be designated by the President, or designated jointly by the Director of National Intelligence and the head of the department or agency concerned, as an element of the intelligence community.

Interconnection arrangements means arrangements governing the physical connection of two or more networks to allow the use of another's network to hand off traffic where it is ultimately delivered (e.g., connecting a customer of telephone provider A to a customer of telephone company B) or sharing data and other information resources.

Kaspersky Lab-covered article means any hardware, software, or service that—

- (1) Is developed or provided by a Kaspersky Lab-covered entity;
- (2) Includes any hardware, software, or service developed or provided in whole or in part by a Kaspersky Lab-covered entity; or
- (3) Contains components using any hardware or software developed in whole or in part by a Kaspersky Lab-covered entity.

Kaspersky Lab-covered entity means—

- (1) Kaspersky Lab;
- (2) Any successor entity to Kaspersky Lab, including any change in name, e.g., "Kaspersky";
- (3) Any entity that controls, is controlled by, or is under common control with Kaspersky Lab; or
- (4) Any entity of which Kaspersky Lab has a majority ownership.

National security system, as defined in 44 U.S.C. 3552, means any information system (including any telecommunications system) used or operated by an agency or by a contractor of an agency, or other organization on behalf of an agency—

- (1) The function, operation, or use of which involves intelligence activities; involves cryptologic activities related to national security; involves command and control of military forces; involves equipment that is an integral part of a weapon or weapons system; or is critical to the direct fulfillment of military or intelligence missions, but does not include a system that is to be used for routine administrative and business applications (including payroll, finance, logistics, and personnel management applications); or
- (2) Is protected at all times by procedures established for information that have been specifically authorized under criteria established by an Executive order or an Act of Congress to be kept classified in the interest of national defense or foreign policy.

Roaming means cellular communications services (e.g., voice, video, data) received from a visited network when unable to connect to the facilities of the home network either because signal coverage is too weak or because traffic is too high.

Sensitive compartmented information means classified information concerning or derived from intelligence sources, methods, or analytical processes, which is required to be handled within formal access control systems established by the Director of National Intelligence.

Sensitive compartmented information system means a national security system authorized to process or store sensitive compartmented information.

Source means a non-Federal supplier, or potential supplier, of products or services, at any tier.

Subsidiary means an entity in which more than 50 percent of the entity is owned directly by a parent corporation or through another subsidiary of a parent corporation.

Substantial or essential component means any component necessary for the proper function or performance of a piece of equipment, system, or service.

Unmanned aircraft means an aircraft that is operated without the possibility of direct human intervention from within or on the aircraft (49 U.S.C. 44801(11)).

Unmanned aircraft system means an unmanned aircraft and associated elements (including communication links and the components that control the unmanned aircraft) that are required for the operator to operate safely and efficiently in the national airspace system (49 U.S.C. 44801(12)).

(b) *Prohibitions on providing or using specific products or services in performance of contract.* Unless a waiver or exception applies, the Contractor is prohibited from providing any products or services to the Government or using in the performance of the contract any of the following:

(1) A covered application on any information technology owned or managed by the Government, or on any information technology used or provided by the Contractor under this contract, including equipment provided by the Contractor's employees (section 102 of Division R of the Consolidated Appropriations Act, 2023 (Pub. L. 117-328));

(2) A Kaspersky Lab-covered article (Section 1634 of Division A of the National Defense Authorization Act for Fiscal Year 2018 (Pub. L. 115-91));

(3) Covered telecommunications equipment or services used as a substantial or essential component of any system, or as critical technology as part of any system (paragraphs (a)(1)(A) of section 889 of the John S. McCain National Defense Authorization Act for Fiscal Year 2019 (Pub. L. 115-232)). This does not prohibit contractors from providing—

(i) A service that connects to the facilities of a third-party, such as backhaul, roaming, or interconnection arrangements; or

(ii) Telecommunications equipment that cannot route or redirect user data traffic or cannot permit visibility into any user data or packets that such equipment transmits or otherwise handles.

(c) Prohibition on unmanned aircraft systems manufactured or assembled by American Security Drone Act—covered foreign entities.

(1) Prohibition. The Contractor is prohibited from—

(i) Delivering any FASC-prohibited unmanned aircraft system, which includes unmanned aircraft (i.e., drones) and associated elements (sections 1823 and 1826 of American Security Drone Act of 2023, within the National Defense Authorization Act for Fiscal Year 2024, Pub. L. 118-31, Div. A, Title XVIII, Subtitle B, 41 U.S.C. 3901 note prec.);

(ii) On or after December 22, 2025, operating a FASC-prohibited unmanned aircraft system in the performance of the contract (section 1824 of Pub. L. 118-31); and

(iii) On or after December 22, 2025, using Federal funds to procure or operate a FASC-prohibited unmanned aircraft system (section 1825 of Pub. L. 118-31).

(2) *Procedures.* The Contractor shall search SAM for the FASC-maintained list of American Security Drone Act—covered foreign entities before proposing, or using in performance of the contract, any unmanned aircraft system. Also, the Contractor shall ensure any effort or expenditure associated with a FASC-prohibited unmanned aircraft system is consistent with a corresponding exemption, exception, or waiver determination expressly stated in the contract.

(3) *Exemptions, exceptions, and waivers.* The prohibitions in paragraph (c) of this clause do not apply where the agency has determined an exemption, exception, or waiver applies, and the contract indicates that such a determination has been made. See sections 1823 through 1825 and 1832 of Public Law 118-31 for statutory requirements pertaining to exemptions, exceptions, and waivers.

(d) *Prohibition on using or providing specific products or services or conducting certain transactions regardless of connection to contract.*

(1) *Certain telecommunications and video surveillance equipment, systems, or services.*

(i) Unless an applicable waiver has been issued by the Government, the Contractor cannot use any equipment, systems, or services that uses covered telecommunications equipment or services as a substantial or essential component of any system, or as critical technology as part of any system (paragraph (a)(1)(B) of section 889 of the John S. McCain National Defense Authorization Act for Fiscal Year 2019 (Pub. L. 115-232)).

(ii) This prohibition applies to using covered telecommunications equipment or services, regardless of whether that use is in performance of work under a Federal contract. This does not prohibit the contractor from using—

(A) A service that connects to the facilities of a third party, such as backhaul, roaming, or interconnection arrangements; or

(B) Telecommunications equipment that cannot route or redirect user data traffic or cannot permit visibility into any user data or packets that such equipment transmits or otherwise handles.

(2) Office of Foreign Assets Control Restrictions.

(i) Except as authorized by the Office of Foreign Assets Control (OFAC) in the Department of the Treasury, the Contractor shall not acquire, for use in the performance of this contract, any supplies or services if any proclamation, Executive order, or statute administered by OFAC, or if OFAC's implementing regulations at 31 CFR chapter V, would prohibit such a transaction by a person subject to the jurisdiction of the United States.

(ii) Except as authorized by OFAC, most transactions involving Cuba, Iran, and Sudan are prohibited, as are most imports from Burma or North Korea, into the United States or its outlying areas.

(A) For lists of entities and individuals subject to economic sanctions, see OFAC's List of Specially Designated Nationals and Blocked Persons at <https://home.treasury.gov/policy-issues/financial-sanctions/specially-designated-nationals-and-blocked-persons-list-sdn-human-readable-lists>.

(B) For more information about these restrictions, as well as updates, see OFAC's regulations at 31 CFR chapter V and at <https://home.treasury.gov/policy-issues/office-of-foreign-assets-control-sanctions-programs-and-information>.

(C) To conduct electronic screens of potential parties to regulated transactions, see the consolidated screening list at <https://www.trade.gov/consolidated-screening-list>, which consolidates multiple export screening lists of the Departments of Commerce, State, and the Treasury.

(3) Sudan prohibition. The Contractor is prohibited from conducting any restricted business operations in Sudan in accordance with Accountability and Divestment Act of 2007 (Pub. L. 110-174).

(4) Iran prohibitions.

(i) Unless an exception applies according to paragraph (d)(4)(iii) or the Government grants a waiver, the contractor shall not engage in certain activities or transactions relating to Iran (section 6(b)(1)(A) of Iran Sanctions Act (50 U.S.C. 1701 note)).

(ii) Unless an exception applies according to paragraph (d)(4)(iii) or the Government grants a waiver, contractor shall not export certain sensitive technology to Iran, as determined by the President, and has an active exclusion in SAM (22 U.S.C. 8515).

(iii) The prohibition in paragraphs (d)(4)(i) and (d)(4)(ii) do not apply if the acquisition is subject to trade agreements and the offeror certifies that all the offered products are designated country end products or designated country construction material (see part 25).

(iv) Unless an exception applies or the Government grants a waiver, contractors are prohibited from knowingly engaging in any significant transaction (i.e., over \$15,000) with Iran's Revolutionary Guard Corps or any of its officials, agents, or affiliates, the property and interests in property of which are blocked according to the International Emergency Economic Powers Act (section 6(b)(1)(B) of Iran Sanctions Act (50 U.S.C. 1701 note)).

(e) Governmentwide exclusion and removal orders.

(1) Unless the Government has issued an applicable waiver, contractors shall not provide or use as part of the performance of the contract any covered article, or any products or services produced or provided by a source, if the covered article or the source is prohibited by an applicable FASCSA order as follows:

(i) For solicitations and contracts awarded by a Department of Defense contracting office, DoD FASCSA orders apply.

(ii) For all other solicitations and contracts, DHS FASCSA orders apply.

(2) The Contractor shall search for the phrase "FASCSA order" in the System for Award Management (SAM) at <https://www.sam.gov> to locate applicable FASCSA orders.

(3) The Government may identify in the solicitation other FASCSA orders that are not in SAM, which are effective and apply to the solicitation and resulting contract.

(4) A FASCSA order issued after the date of solicitation applies to this contract only if added by an amendment to the solicitation or modification to the contract (see FAR 40.204-1(c)).

(f) *Reasonable inquiry.* The contractor shall conduct a reasonable inquiry to determine if there are any prohibited products or services. The inquiry will look at any information in the entity's possession but does not need to include an internal or third-party audit.

(g) *Removal of prohibited products and services.* For Federal Supply Schedules, Governmentwide acquisition contracts, multi-agency contracts or any other procurement instrument intended for use by multiple agencies, upon notification from the Contracting Officer, during the performance of the contract, the Contractor shall promptly make any necessary changes or modifications to remove any product or service produced or provided by a source that this clause prohibits.

(h) *General report.*

(1) If the Contractor identifies or is notified by any source, (including a subcontractor at any tier), that any product or service provided or used (or to be provided or used) during contract performance does not comply with any prohibition in this clause, then the Contractor shall report the following information, or as much information is known, in writing to the contracting office as identified in paragraph (h)(2) within 72 hours:

(i) Contract number and order number, if applicable;

(ii) The specific prohibition the product or service is not complying with;

(iii) A description of the products or services that the Contractor identifies or has reason to suspect is prohibited (include brand; model number, such as the original equipment manufacturer (OEM) number, manufacturer part number, or wholesaler number; and item description, as applicable);

(iv) The entity that produced the product or service (include entity name, unique entity identifier, Contractor and Government Entity (CAGE) code, facilities responsible for design, fabrication, assembly, packaging, and test of the product, and whether the entity was the OEM or a distributor (provide manufacturer codes and distributor codes used for the product));

(v) Description of the functionality of the product or service and how that functionality impacts the risk to the product or service;

(vi) An explanation of any factors relevant to determining if the product or service should be permitted by an applicable exception, exemption, or waiver (if the contractor would like the Government to consider a waiver, and asks for such a waiver);

(vii) Whether alternative products or services are available that would comply with the prohibition;

(viii) If the product or service is related to item maintenance, include the following information on the item being maintained:

(A) Brand;

(B) Model number, OEM number, manufacturer part number, or wholesaler number; and

(C) Item description, as applicable.

(ix) Any readily available information about mitigation actions implemented or recommended.

(2) If a report must be submitted to a contracting office, the Contractor shall submit the report as follows:

(i) If a Department of Defense contracting office, the Contractor shall report to the website at <https://dibnet.dod.mil>.

(ii) For all other contracting offices, the Contractor shall report to the Contracting Officer.

(iii) For indefinite delivery contracts, the Contractor shall report to both the contracting office for the indefinite delivery contract and the contracting office for any affected order.

(3) If the report provided does not contain any of the information required by paragraph (h)(1) of this clause, and the contractor later discovers new information that is required by paragraph (h)(1) of this clause, then the contractor shall submit a subsequent report within 72 hours of discovering the new information.

(4) The contractor shall also report the information in paragraph (h)(1) if the contractor wishes to ask for a waiver of the requirements of a new FASCSA order being applied through modification.

(i) *New FASCSA orders report.*

(1) During contract performance, the Contractor shall review SAM at least once every three months, or as advised by the Contracting Officer, to check for covered articles subject to FASCSA order(s), or for products or services produced by a source subject to FASCSA order(s) not currently identified under paragraph (e) of this clause.

(2) If the Contractor identifies a new FASCSA order(s) that could impact their supply chain, then the Contractor shall conduct a reasonable inquiry to identify whether a covered article or product or service produced or provided by a source subject to the FASCSA order(s) was provided to the Government or used during contract performance. The inquiry will look at any information in the entity's possession but does not need to include an internal or third-party audit.

(3) The Contractor shall submit a report to the contracting office identified in paragraph (h)(2) of this clause if the Contractor identifies, including through any notification by a subcontractor at any tier, that a covered article or product or service produced or provided by a source was provided to the Government or used during contract performance and is subject to a FASCSA order(s). For indefinite delivery contracts, the Contractor shall report to both the contracting office for the indefinite delivery contract and the contracting office for any affected order. The Contractor shall report the following information within 72 hours for each covered article or each product or service produced or provided by a source, where the covered article or source is subject to a FASCSA order:

(i) Contract number and order number, if applicable;

(ii) Name of the covered article or source subject to a FASCSA order;

(iii) The specific FASCSA order the product or service does not comply with;

(iv) The elements of (h)(1)(iii) through (ix) of this clause.

(j) *Subcontracts.* The Contractor shall insert the substance of this clause, including this paragraph (j) but excluding subparagraphs (d)(1) and (i)(1), in all subcontracts and other contractual instruments, including subcontracts for acquiring commercial products or commercial services.

(End of clause)

2852.201-70 Contracting Officer's Representative (COR) (NOV 2020)

- (a) Mr./Ms. Brian McDonough of Health Services Division , 320 First Street, NW, Washington, DC 20534 , 202-598-3411 , is hereby designated to act as Contracting Officer's Representative (COR) under TBD , for the period of contract start through contract completion.
- (b) Performance of work under this contract is subject to the technical direction of the COR identified above, or another representative designated in writing by the Contracting Officer. The term "technical direction" includes, without limitation, the following:
- (i) Receiving all deliverables;
 - (ii) Inspecting and accepting the supplies or services provided in accordance with the terms and conditions of this contract;
 - (iii) Clarifying, directing, or redirecting the contract effort, including shifting work between work areas and locations, filling in details, or otherwise serving to accomplish the contractual statement of work to ensure the work is accomplished satisfactorily;
 - (iv) Evaluating performance of the Contractor; and
 - (v) Certifying all invoices/vouchers for acceptance of the supplies or services furnished for payment.
- (c) The COR does not have the authority to issue direction that:
- (i) Constitutes a change of assignment or work outside the contract specification/work statement/scope of work.
 - (ii) Constitutes a change as defined in the clause entitled "Changes" or other similar contract term.
 - (iii) Causes, in any manner, an increase or decrease in the contract price or the time required for contract performance;
 - (iv) Causes, in any manner, any change in a term, condition, or specification or the work statement/scope of work of the contract;
 - (v) Causes, in any manner, any change or commitment that affects price, quality, quantity, delivery, or other term or condition of the contract or that, in any way, directs the contractor or its subcontractors to operate in conflict with the contract terms and conditions;
 - (vi) Interferes with the contractor's right to perform under the terms and conditions of the contract;
 - (vii) Directs, supervises, or otherwise controls the actions of the Contractor's employees or a Subcontractor's employees.
- (d) The Contractor shall proceed promptly with performance resulting from the technical direction of the COR. If, in the opinion of the Contractor, any direction by the COR or the designated representative falls outside the authority of (b) above and/or within the limitations of (c) above, the Contractor shall immediately notify the Contracting Officer.
- (e) Failure of the Contractor and Contracting Officer to agree that technical direction is within the scope of the contract is a dispute that shall be subject to the "Disputes" clause and/or other similar contract term.
- (f) COR authority is not re-delegable.

(End of Clause)

2852.223-70 Unsafe Conditions Due to the Presence of Hazardous Material (NOV 2020)

- (a) "Unsafe condition" as used in this clause means the actual or potential exposure of Contractor or Government employees to a hazardous material.
- (b) "Hazardous Material" as used in this clause includes any material defined as hazardous under the latest version of Federal Standard No. 313 (including revisions adopted during the term of the contract), any other potentially hazardous material requiring safety controls, or any other material or working condition designated as hazardous by the Contracting Officer's Representative (COR).
- (c) The Occupational Safety and Health Administration (OSHA) is responsible for issuing and administering regulations that require Contractors to apprise its employees of all hazards to which they may be exposed in the course of their employment; proper conditions and precautions for safe use and exposure; and related symptoms and emergency treatment in the event of exposure.
- (d) Prior to commencement of work, Contractors are required to inspect for and report to the Contracting Officer the presence of, or suspected presence of, any unsafe condition including asbestos or other hazardous materials or working conditions in areas in which they will be working.
- (e) If during the performance of the work under this contract, the Contractor or any of its employees, or subcontractor employees, discovers the existence of an unsafe condition, the Contractor shall immediately notify the Contracting Officer, or designee (with written notice provided not later than three (3) working days thereafter), of the existence of an unsafe condition. Such notice shall include the Contractor's recommendations for the protection and the safety of Government, Contractor and subcontractor personnel and property that may be exposed to the unsafe condition.
- (f) When the Government receives notice of an unsafe condition from the Contractor, the parties will agree on a course of action to mitigate the effects of that condition and, if necessary, the contract will be amended. Failure to agree on a course of action will constitute a dispute under the Disputes clause of this contract.

(g) Nothing contained in this clause shall relieve the Contractor or subcontractors from complying with applicable Federal, State, and local laws, codes, ordinances and regulations (including the obtaining of licenses and permits) in connection with hazardous material including but not limited to the use, disturbance, or disposal of such material.
(End of Clause)

DOJ-01 Whistleblower Information Distribution (Oct 2021)

Within 30 days of contract award, the contractor and its subcontractors must distribute the "Whistleblower Information for Employees of DOJ Contractors, Subcontractors, Grantees, or Sub-Grantees or Personal Services Contractors" ("Whistleblower Information") document to their employees performing work in support of the products and services delivered under this contract (<https://oig.justice.gov/sites/default/files/2020-04/NDAA-brochure.pdf>). By agreeing to the terms and conditions of this contract, the prime contractor acknowledges receipt of this requirement, in accordance with 41 U.S.C. § 4712 and FAR 3.906 & 52.203-17, and commits to distribution. Within 45 days of award, the contractor must provide confirmation to the contracting officer verifying that it has distributed the whistleblower information as required.

(End of Clause)

DOJ-02 Contractor Privacy Requirements (JAN 2022)

A. Limiting Access to Privacy Act and Other Sensitive Information

(1) Privacy Act Information

In accordance with FAR 52.224-1 Privacy Act Notification (APR 1984) and FAR 52.224-2 Privacy Act (APR 1984), if this contract requires Contractor personnel to have access to information protected by the Privacy Act of 1974, the contractor is advised that the relevant DOJ system of records notices (SORNs) applicable to this Privacy Act information may be found at <https://www.justice.gov/opcl/doj-systems-records>. [1] Applicable SORNs published by other agencies may be accessed through those agencies' websites or by searching the Federal Digital System (FDsys) available at <http://www.gpo.gov/fdsys/>. SORNs may be updated at any time.

(2) Prohibition on Performing Work Outside a Government Facility/Network/Equipment

Except where use of Contractor networks, IT, other equipment, or Workplace as a Service (WaaS) is specifically authorized within this contract, the Contractor shall perform all tasks on authorized Government networks, using Government-furnished IT and other equipment and/or WaaS and Government information shall remain within the confines of authorized Government networks at all times. Any handling of Government information on Contractor networks or IT must be approved by the Senior Component Official for Privacy of the component entering into this contract. Except where remote work is specifically authorized within this contract, the Contractor shall perform all tasks described in this document at authorized Government facilities; the Contractor is prohibited from performing these tasks at or removing Government-furnished information to any other facility; and Government information shall remain within the confines of authorized Government facilities at all times. Contractors may only access classified materials on government furnished equipment in authorized government owned facilities regardless of remote work authorizations.

(3) Prior Approval Required to Hire Subcontractors

The Contractor is required to obtain the Contracting Officer's approval prior to engaging in any contractual relationship (Subcontractor) in support of this contract requiring the disclosure of information, documentary material and/or records generated under or relating to this contract. The Contractor (and any Subcontractor) is required to abide by Government and Agency guidance for protecting sensitive and proprietary information.

(4) Separation Checklist for Contractor Employees

The Contractor shall complete and submit an appropriate separation checklist to the Contracting Officer before any employee or Subcontractor employee terminates working on the contract. The Contractor must submit the separation checklist on or before the last day of employment or work on the contract. The separation checklist must verify: (1) return of any Government-furnished equipment; (2) return or proper disposition of personally identifiable information (PII)[2], in paper or electronic form, in the custody of the employee or Subcontractor

employee including the sanitization of data on any computer systems or media as appropriate; and (3) termination of any technological access to the Contractor's facilities or systems that would permit the terminated employee's access to PII or other sensitive information.

In the event of adverse job actions resulting in the dismissal of a Contractor or Subcontractor employee before the separation checklist can be completed, the Prime Contractor must notify the Contracting Officer within 24 hours and confirm receipt of the notification. In the case the Contractor is unable to notify the Contracting Officer, then the Contractor should notify the Contract Officer's Representative (COR).

Contractors must complete the separation checklist with the Contracting Officer or COR by returning all Government-furnished property including, but not limited to, computer equipment, media, credentials and passports, smart cards, mobile devices, Personal Identity Verification (PIV) cards, calling cards, and keys and terminating access to all user accounts and systems. Unless the Contracting Officer requests otherwise, the relevant Program Manager or other Key Personnel designated by the Contracting Officer or COR may facilitate the return of equipment.

B. Privacy Training, Safeguarding, and Remediation

(1) Required Security and Privacy Training for Contractors

The Contractor must ensure that all employees take appropriate privacy training, including Subcontractors who have access to PII as well as the creation, use, dissemination and/or destruction of PII at the outset of the employee's work on the contract and every year thereafter. Training must include procedures on how to properly handle PII, including heightened security requirements for the transporting or transmission of sensitive PII, and reporting requirements for a suspected breach or loss of PII. These courses, along with more information about DOJ security and training requirements for Contractors, are available at <https://www.justice.gov/jmd/learndoj>. The Federal Information Security Modernization Act of 2014 (FISMA) requires all individuals accessing DOJ information to complete training on records management, cybersecurity awareness, and information system privacy awareness. Contractor employees are required to sign the "Privacy Rules of Behavior," acknowledging and agreeing to abide by privacy law, policy, and certain privacy safeguards, prior to accessing DOJ information. These Rules of Behavior are made available to all new users of DOJ's computer network and to trainees at the conclusion of DOJ-OPCL-CS-0005.

The Contractor should maintain copies of certificates as a record of compliance and must submit an email notification annually to the COR verifying that all employees working under this contract have completed the required privacy and cybersecurity training.

(2) Safeguarding PII Requirements

Contractor employees must comply with DOJ Order 0904 and other guidance published to the publicly-available Office of Privacy and Civil Liberties (OPCL) Resources page[3] relating to the safeguarding of PII, including the use of additional controls to safeguard sensitive PII (e.g., the encryption of sensitive PII). This requirement flows down from the Prime Contractor to all Subcontractors and lower tiered subcontracts.

(3) Non-Disclosure Agreement Requirement

Prior to commencing work, all Contractor personnel that may have access to PII or other sensitive information shall be required to sign a Non-Disclosure Agreement (NDA) and the DOJ IT Rules of Behavior. The Non-Disclosure Agreement:

- (a) prohibits the Contractor from retaining or divulging any PII or other sensitive information, or derivatives therefrom, furnished by the Government or to which they may otherwise come in contact as a result of their performance of work under the contract/task order that is otherwise not publicly available, whether or not such information has been reduced to writing; and
- (b) requires the Contractor to report any loss of control, compromise, unauthorized disclosure, or unauthorized acquisition of PII or other sensitive information to the component-level or headquarters Security Operations Center within one (1) hour of discovery.

The Contractor should maintain signed copies of the NDA for all employees as a record of compliance. The Contractor should also provide copies of each employee's signed NDA to the Contracting Officer before the employee may commence work under the contract/task order.

(4) Prohibition on Use of PII in Vendor Billing and Administrative Records

The Contractor's invoicing, billing, and other financial or administrative records or databases is not authorized to regularly store or include any sensitive PII or other confidential government information that is created, obtained, or provided during the performance of the contract without the written permission of the Senior Component Official for Privacy (SCOP). It is acceptable to list the names, titles and contact information for the Contracting Officer, COR, or other personnel associated with the administration of the contract in the invoices as needed.

(5) Reporting Actual or Suspected Data Breach

Contractors must report any actual or suspected breach of PII within one hour of discovery.[4] A "breach" is an incident or occurrence that involves the loss of control, compromise, unauthorized disclosure, unauthorized acquisition, or any similar occurrence where: (1) a person other than an authorized user accesses or potentially accesses PII or (2) an authorized user accesses or potentially accesses PII for an other than authorized purpose. The report of a breach must be made to DOJ. The Contractor must cooperate with DOJ's inquiry into the incident and efforts to minimize risks to DOJ or individuals, including remediating any harm to potential victims.

(a) The Contractor must develop and maintain an internal process by which its employees and Subcontractors are trained to identify and report the breach, consistent with DOJ Instruction 0900.00.01[5], Reporting and Response Procedures for a Breach of Personally Identifiable Information.

(b) The Contractor must report any such breach by its employees or Subcontractors to the DOJ Security Operations Center (dojcert@usdoj.gov, 202-357-7000); Component-level Security Operations Center and Component-level Management Team, where appropriate; the COR; and the Contracting Officer within one (1) hour of the initial discovery.

(c) The Contractor must provide a written report to the DOJ Security Operations Center (dojcert@usdoj.gov, 202-357-7000) within 24 hours of discovery of the breach by its employees or Subcontractors. The report must contain the following information:

- (i) Narrative or detailed description of the events surrounding the suspected loss or compromise of information.[6] Date, time, and location of the incident.
- (ii) Amount, type, and sensitivity of information that may have been lost or compromised, accessed without authorization, etc.
- (iii) Contractor's assessment of the likelihood that the information was compromised or lost and the reasons behind the assessment.[7]
- (iv) Names and classification of person(s) involved, including victim, Contractor employee/Subcontractor and any witnesses.
- (v) Cause of the incident and whether the company's security plan was followed and, if not, which specific provisions were not followed.[8]
- (vi) Actions that have been or will be taken to minimize damage and/or mitigate further compromise.
- (vii) Recommendations to prevent similar situations in the future, including whether the security plan needs to be modified in any way and whether additional training may be required.

(d) The Contractor shall provide full access and cooperation for all activities determined by the Government to be required to ensure an effective incident response, including providing all requested images, log files, and event information to facilitate rapid resolution of sensitive information incidents.

(e) At the Government's discretion, Contractor employees or Subcontractor employees may be identified as no longer eligible to access PII or to work on that contract based on their actions related to the loss or compromise of PII.

(6) Victim Remediation

At DOJ's request, the Contractor is responsible for notifying victims and providing victim remediation services in the event of a breach of PII held by the Contractor, its agents, or its Subcontractors, under this contract. Victim

remediation services shall include at least 18 months of credit monitoring and, for serious or large incidents as determined by the Government, call center help desk services for the individuals whose PII was lost or compromised. When DOJ requests notification, the Department Chief Privacy and Civil Liberties Officer and SCOP will direct the Contractor on the method and content of such notification to be sent to individuals whose PII was breached. By performing this work, the Contractor agrees to full cooperation in the event of a breach. The Contractor should be self-insured to the extent necessary to handle any reasonably foreseeable breach, with another source of income, to fully cover the costs of breach response, including but not limited to victim remediation.

C. Government Records Training, Ownership, and Management

(1) *Records Management Training and Compliance*

(a) The Contractor must ensure that all employees and Subcontractors that have access to PII as well as to those involved in the creation, use, dissemination and/or destruction of PII take the *DOJ Records and Information Training for New Employees (RIM)* training course or another training approved by the Contracting Officer or COR. This training will be provided at the outset of the Subcontractor's/employee's work on the contract and every year thereafter. The Contractor shall maintain copies of certificates as a record of compliance and must submit an email notification annually to the COR verifying that all employees working under this contract have completed the required records management training.

(b) The Contractor agrees to comply with Federal and Agency records management policies, including those policies associated with the safeguarding of records containing PII and those covered by the Privacy Act of 1974. These policies include the preservation of all records created or received regardless of format, mode of transmission, or state of completion.

(2) *Records Creation, Ownership, and Disposition*

(a) The Contractor shall not create or maintain any records not specifically tied to or authorized by the contract using Government IT equipment and/or Government records or that contain Government Agency information. The Contractor shall certify, in writing, the appropriate disposition or return of all Government information at the conclusion of the contract or at a time otherwise specified in the contract. In accordance with 36 CFR 1222.32, the Contractor shall maintain and manage all Federal records created in the course of performing the contract in accordance with Federal law. Records may not be removed from the legal custody of DOJ or destroyed except in accordance with the provisions of the agency records schedules.

(b) Except as stated in the Performance Work Statement and, where applicable, the Contractor's Commercial License Agreement, the Government Agency owns the rights to all electronic information (electronic data, electronic information systems or electronic databases and all supporting documentation and associated metadata created as part of this contract. All deliverables (including all data and records) under the contract are the property of the U.S. Government and may be considered federal records, for which the Agency shall have unlimited rights to use, dispose of, or disclose such data contained therein. The Contractor must deliver sufficient technical documentation with all data deliverables to permit the agency to use the data.

(c) The Contractor shall not retain, use, sell, disseminate, or dispose of any government data/records or deliverables without the express written permission of the Contracting Officer or Contracting Officer's Representative. The Agency and its contractors are responsible for preventing the alienation or unauthorized destruction of records, including all forms of mutilation. Willful and unlawful destruction, damage or alienation of Federal records is subject to the fines and penalties imposed by 18 U.S.C. § 2701. Records may not be removed from the legal custody of the Agency or destroyed without regard to the provisions of the Agency records schedules.

D. Data Privacy and Oversight

(1) *Restrictions on Testing or Training Using Real Data Containing PII*

The use of real data containing PII from any source for testing or training purposes is generally prohibited. The Contractor shall use synthetic or de-identified real data for testing or training whenever feasible.

(2) *Requirements for Contractor IT Systems Hosting Government Data*

The Contractor is required to obtain an Authority To Operate (ATO) for any IT environment owned or controlled by the Contractor or any Subcontractor on which Government data shall reside for the purposes of IT system development, design, data migration, testing, training, maintenance, use, or disposal.

(3) Requirement to Support Privacy Compliance

(a) If this contract requires the development, maintenance or administration of information technology[9], the Contractor shall support the completion of the Initial Privacy Assessment (IPA) document, if requested by Department personnel. An IPA is the first step in a process to identify potential privacy issues and mitigate privacy risks. The IPA asks basic questions to help components assess whether additional privacy protections may be needed in designing or implementing a project[10] to mitigate privacy risks, and whether compliance work may be needed. Upon review of the IPA, the OPCL determines whether a Privacy Impact Assessment (PIA) document and/or SORN, or modifications thereto, are required. The Contractor shall provide adequate support to complete the applicable risk assessment and PIA document in a timely manner, and shall ensure that project management plans and schedules include the IPA, PIA, and SORN (to the extent required) as milestones. Additional information on the privacy compliance process at DOJ, including IPAs, PIAs, and SORNs, is located on the DOJ OPCL website (<https://dojnet.doj.gov/privacy/>), including DOJ Order 0601, Privacy and Civil Liberties. The Privacy Impact Assessment Guidance and Template outline the requirements and format for the PIA.

(b) If the contract involves an IT system build or substantial development or changes to an IT system that may require privacy risk assessment and documentation, the Contractor shall provide adequate support to DOJ to ensure DOJ can complete any required assessment, and IPA, PIA, SORN, or other supporting documentation to support privacy compliance. The Contractor shall work with personnel from the program office, OPCL, the Office of the Chief Information Officer (OCIO), and the Office of Records Management and Policy to ensure that the privacy assessments and documentation are kept on schedule, that the answers to questions in the documents are thorough and complete, and that questions asked by the OPCL and other offices are answered in a timely fashion. The Contractor must ensure the completion of required PIAs and documentation of privacy controls consistent with federal law and standards, e.g. NIST 800-53, Rev. 5; and compliance with the Privacy Act of 1974, E-Government Act of 2002, Federal Information Security Modernization Act of 2014, and key OMB guidelines, e.g., OMB Circular A-130.

[1] “[T]he term ‘record’ means any item, collection, or grouping of information about an individual that is maintained by an agency, including, but not limited to, his education, financial transactions, medical history, and criminal or employment history and that contains his name, or the identifying number, symbol, or other identifying particular assigned to the individual, such as a finger or voice print or a photograph.” 5 U.S.C. § 552a(a)(4). “[T]he term ‘system of records’ means a group of any records under the control of any agency from which information is retrieved by the name of the individual or by some identifying number, symbol, or other identifying particular assigned to the individual.” 5 U.S.C. § 552a(a)(5).

[2] As stated in FAR 52.224-3 and Office of Management and Budget (OMB) Circular A-130, Managing Federal Information as a Strategic Resource (2016), “‘personally identifiable information’ means information that can be used to distinguish or trace an individual’s identity, either alone or when combined with other information that is linked or linkable to a specific individual.” Regarding “sensitive PII,” “[t]he sensitivity level of the PII will depend on the context, including the purpose for which the PII is created, collected, used, processed, stored, maintained, disseminated, disclosed, or disposed. For example, the sensitivity level of a list of individuals’ names may depend on the source of the information, the other information associated with the list, the intended use of the information, the ways in which the information will be processed and shared, and the ability to access the information.” OMB Circular A-130, at App. II-2.

[3] The DOJ OPCL Resources page is available at <https://www.justice.gov/opcl/resources>.

[4] As stated in DOJ Instruction 0900, “Contractors must notify the Contracting Officer, the Contracting Officer’s Representative, and JSOC (or component-level SOC) within 1 hour of discovering any incidents, including breaches, consistent with this Instruction, guidance issued by the CPCLO, NIST standards and guidelines, and the US-CERT notification guidelines.”

[5] <https://www.justice.gov/file/4336/download>

[6] As stated in DOJ Instruction 0900, the description should include the type of information that constitutes PII; purpose for which PII is collected, maintained, and used; extent to which PII identifies a peculiarly vulnerable population; the determination of whether the information was properly encrypted or rendered partially or completely inaccessible by other means; format of PII (e.g., whether PII was structured or unstructured); length of time PII was exposed; any evidence confirming that PII is being misused or that it was never accessed.

[7] As stated in DOJ Instruction 0900, the report should include the nature of the cyber threat (e.g., Advanced Persistent Threat, Zero Day Threat, data exfiltration) for cyber incidents.

[8] As stated in DOJ Instruction 0900, the report should include analysis on whether the data is accessible, usable, and intentionally targeted.

[9] As defined in 40 U.S.C. § 11101, the term “information technology” means any equipment or interconnected system or subsystem of equipment, used in the automatic acquisition, storage, analysis, evaluation, manipulation, management, movement, control, display, switching, interchange, transmission, or reception of data or information by the executive agency, if the equipment is used by the executive agency directly or is used by a contractor under a contract with the executive agency that requires the use (i) of that equipment or (ii) of that equipment to a significant extent in the performance of a service or the furnishing of a product; includes computers, ancillary equipment (including imaging peripherals, input, output, and storage devices necessary for security and surveillance), peripheral equipment designed to be controlled by the central processing unit of a computer, software, firmware and similar procedures, services (including support services), and related resources; but does not include any equipment acquired by a federal contractor incidental to a federal contract.

[10] In this instance, the term “project” is used to scope the activities (e.g., creating, collecting, using, processing, storing, maintaining, disseminating, disclosing, or disposing of information) covered by an IPA. A project is intended to be technology-neutral, and may include an information system, a digital service, an information technology, a combination thereof, or some other activity that may create potential privacy issues or privacy risks that would benefit from an IPA. The scope of a project covered by an IPA is discretionary, but components should work with their SCOP and OPCL.

(End of Clause)

DOJ-03 Personnel Security Requirements For Contractor Employees (Nov 2021)

Work performed under this contract will involve any one or more of the following: access to DOJ Information, which may include Controlled Unclassified Information (CUI), i.e., unclassified, sensitive DOJ information, and/or access to DOJ Information Technology (IT) systems, and/or unescorted access to DOJ space or facilities. Contractor employees will occupy Public Trust Positions, unless clause alternates are applied.

1. General Requirements

(a) (1) All references to “contract(or) personnel” and “contract(or) employee” in this clause means all individuals, without limitation, to include individuals employed by the contractor, team member, subcontractor, consultant, and/or independent contractor, who will have access to information of the Department of Justice (DOJ) or information that is within the custody and control of the DOJ, access to DOJ IT systems, and/or unescorted access to DOJ facilities/space in connection with the performance of this contract. “Employment” as used herein does not create nor imply an employer/employee relationship between the DOJ and contractor employees.

(b) (1) The type of security investigation required for each contractor employee will be governed by the type and risk level of information made available to the contractor employee. The contractor will not be permitted to commence performance under this contract until a sufficient number of its personnel, as determined by the Security Programs Manager (SPM), in consultation with the Contracting Officer’s Representative if one is appointed, have received the requisite security approval.

(c) Except where specifically noted otherwise, the federal government will be responsible for the cost and conduct of the investigation.

(d) The contractor shall ensure that no contractor employee commences performance prior to receipt of a written authorization from the contracting officer, COR, or the SPM that performance by the respective contractor employee is authorized.

(e) The data and other information to which the contractor may have access as a result of this contract is the property of, and/or within the custody and control of, the Department, and its disclosure to third parties is governed by various statutes and regulations, the violation of which may subject the discloser to criminal penalties.

2. Citizenship and Residency Requirements

(a) *Residency Requirement.* (1) Contractor employees in Public Trust positions, both U.S. citizens and non-U.S. citizens, must meet the Department’s residency requirement if they will require access to DOJ information, IT systems, or unescorted access to facilities. For three years (not necessarily consecutive years) out of the last five years immediately prior to employment under the Department contract the contractor employee must have: (i) resided in the U.S.; (ii) worked

for the U.S. in a foreign country as either an employee or contractor in a federal civilian or military capacity; or, (iii) been a dependent of a federal civilian or military employee or contractor working for the U.S. in a foreign country. At the Department's sole discretion, the residency requirement may be waived by the Department Security Officer (DSO) for contractor employees on a case-by-case basis where justified by extenuating circumstances. The residency requirement does not apply to contractor employees residing in foreign countries that are hired to work in American embassies/consulates/missions located outside of the United States and who require access to DOJ information, IT systems, or unescorted access *provided that* an adequate background investigation can be conducted, with favorable adjudication, as determined by the DSO.

(b) *Citizenship.* (1) Aside from the specific exceptions set forth in Section 1.2(b)(2), for Public Trust positions, the DOJ requires that contractor employees be U.S. citizens and nationals, or lawful permanent residents seeking U.S. citizenship. Any prospective non-U.S. citizen contractor employee who requires access to DOJ information systems, DOJ information, and/or unescorted facilities access must also have been granted a waiver as described below in paragraphs 1.2(d) and/or (e). The contractor is responsible for verifying that the non-U.S. citizens working under this contract are lawful permanent residents seeking U.S. citizenship.

(2) *Exception for Certain Non-U.S. Citizen Contractor Employees:* (i) Non-U.S. citizen expert witnesses, litigative consultants, and interpreters in rare foreign languages are not required to be lawful permanent residents seeking U.S. citizenship. However, they must be granted a waiver for access to unclassified DOJ information, whether CUI or not, DOJ IT systems, and/or unescorted facility access, as described below in paragraph 1.2(d) and (e), regardless of the duration of their duties. (ii) Non-U.S. Citizen contractor employees residing in foreign countries who are hired to work for the Department of Justice in American embassies/consulates/missions outside of the United States are not required to be lawful permanent residents seeking U.S. citizenship.

(c) *Dual Citizenship.* (1) U.S. citizens who hold dual citizenship with a foreign country are considered U.S. citizens within the meaning of this clause, and may be considered for, but are not entitled to, contract employment as U.S. citizens consistent with this clause. The means by which the contractor employee obtained or exercises his or her dual citizenship status will be a consideration in the Public Trust Investigation (PTI) adjudication, and/or waiver approval processes discussed in this clause.

(d) *Access to DOJ Information Technology Systems.* Non-U.S. citizens are not authorized to access DOJ information technology (IT) systems or assist in the development, operation, management, or maintenance of DOJ IT systems, including providing IT system support, unless a waiver has been granted by the Head of the DOJ component or designee, with the prior concurrence of both the DSO and the DOJ Chief Information Officer, allowing computer access by the non-U.S. citizen. Such a waiver will be granted only in exceptional and unique circumstances on a case-by-case basis. It should be noted that the Justice Consolidated Office Network (JCON) is a sensitive DOJ IT system and any contractor employee who will need access to JCON must be a U.S. citizen or have received a waiver. In order for a waiver to be considered for approval: (1) There must be a compelling reason for using this individual as opposed to a U.S. citizen; (2) The type of personnel security vetting that has been conducted on the individual, and vetting results, that would mitigate risk; and (3) The waiver must be in the best interest of the federal government.

(e) *Access to Unclassified DOJ Information and Unescorted Access to DOJ Facilities or Space.* (1) Except as provided under 1.2(b)(2), non-U.S. citizens are not authorized to access DOJ information and/or unescorted access to DOJ facilities or space, unless a waiver has been granted by the DSO, allowing access by the non-U.S. citizen. Such a waiver will be granted on a case-by-case basis where justified at the discretion of the DSO.

3. Background Investigation Requirements

(a) (1) Unless otherwise stated below, all contractor personnel are subject to a Public Trust Investigation (PTI). The SPM will determine the type of investigation for each contractor employee based on the risk category (i.e., the nature of the position and degree of harm that could be caused by the individual in that position) and whether the position is long-term or short-term. The PTI risk categories are listed below.

(i) High Risk Positions. The minimum background investigation required is a Tier 4 (T4) investigation, and the five-year reinvestigation required is a Tier 4R (T4R) investigation. The 2017 version of the Standard Form (SF) 85P, Questionnaire for Public Trust Positions, is required.

(ii) Moderate Risk Positions. The minimum background investigation required is a Tier 2 (T2) investigation. The five-year reinvestigation required is a Tier 2R (T2R) investigation. The 2017 version of the SF-85P is required.

(iii) Low Risk/Non-Sensitive Positions. The minimum background investigation required for Low Risk/Non-Sensitive positions is a Tier 1 (T1) investigation and the required five-year reinvestigation is also a Tier 1 (T1) investigation. The SF 85, Questionnaire for Non-Sensitive Positions, is required.

(b) *Exception for Expert Witnesses*. Expert Witnesses, litigative consultants, and interpreters in rare foreign languages may not be subject to full background investigation requirements if alternative security requirements are approved by the DSO.

(c) *Short-Term U.S. Citizen Contractor Employees*. Other than the exception in Section 1.3(b), short-term contractor employees (6 months or less) who are U.S. citizens are not subject to a full background investigation, however, must receive an approved pre-employment background investigation waiver. The required forms to complete and submit are listed in Section 1.4(b) and (c)(2).

(d) *Long-Term U.S. Citizen Contractor Employees*. Other than the exception in Section 1.3(b), all long-term U.S. citizen employees (longer than 6 months) are subject to a full background investigation in the risk category appropriate to the position they will hold.

(e) *Non-U.S. Citizen Contractor Employees*. Other than the exception in 1.3(b), all non-U.S. citizen contractor employees regardless of performance duration (short or long term) are subject to a full background investigation in the risk category appropriate to the position they will hold.

(f) *Reciprocity*. (1) A Public Trust Investigation will be accepted under reciprocity if it meets the following guidelines: (i) the investigation is current (investigations are considered current if completed within the last five years) and favorably adjudicated, or the reinvestigation has been deferred; (ii) the investigation meets or exceeds the level of investigation required for the DOJ contractual instrument; (iii) there has been no continuous (not cumulative) break in federal contract/service employment of two years or more; (iv) there is no derogatory information since the favorable fitness determination or adjudication that calls into question the individual's fitness based on character or conduct; and (v) the investigative record does not show conduct that is incompatible with the core duties of the new contract position. A "core duty" is a continuing responsibility that is of particular importance to the relevant covered position or the achievement of an agency's mission. Core duties will vary from position to position.

4. Background Investigation Process

(a) *e-QIP (or its successor)*. Public Trust background investigations/reinvestigations of contractor employees will be performed by the DCSA. The investigative process requires contractor employees to complete the Electronic Questionnaires for Investigations Processing (e-QIP) and provide additional information as specified in paragraph 1.4(b) below. Immediately after contract award, the contractor shall designate an employee as its "e-QIP Initiator" and provide the name of this person to the SPM. The e-QIP Initiator must have, at a minimum, a favorably adjudicated Tier 1 investigation and the appropriate DOJ security approval before being given access to e-QIP. After the e-QIP Initiator's security approval is granted, the Contractor will be configured in e-QIP as a sub-agency to DOJ. The contractor will then be responsible for initiating investigations for all contract personnel, whose previous investigation does not meet reciprocity, in e-QIP for completion of the security questionnaire form and forwarding the electronic form with the remainder of the security package to the SPM. Subject to the prior written approval of the SPM, the contractor may designate an e-QIP Initiator for each subcontractor. Subcontractor e-QIP Initiators must have, at a minimum, a favorably adjudicated Tier 1 investigation and the appropriate DOJ security approval before being provided access to e-QIP.

(b) *Additional Documentation*. (1) In addition to completing the e-QIP questionnaire (see 1.4(a), above), the contractor shall ensure that each contractor employee occupying Public Trust Positions, including short-term employees, completes and submits the following information through the contractor's Corporate Security Officer:

(i) Digital Fingerprinting/FD-258 Applicant Fingerprint Card. Two sets are required per applicant. The contractor may schedule appointments with the SPM to be digitally fingerprinted; otherwise, fingerprinting by the FBI or other law enforcement entity, as approved by the SPM, is required to ensure the identity of the person being fingerprinted and for printing quality. All pertinent information must be completed by the individual taking the fingerprints (FBI or other). Use of the physical FD-258 Applicant Fingerprint Card should only be used in extenuating circumstances.

(ii) DOJ-555 Fair Credit Reporting Act Disclosure. Authorizes DOJ to obtain one or more consumer/credit reports on the individual. This form will be required if the Component SPM determines a credit check is necessary for its Low Risk Level 1 contractor positions.

(iii) OF-306, Declaration for Federal Employment.

- (iv) Foreign National Relatives or Associates Statement. This is only required if foreign national relatives or associates were not disclosed on the security questionnaire form.
- (v) Self-Reporting Requirements for All Contractor Personnel. This is an acknowledgement and acceptance statement that every contractor must sign.
- (vi) Additional information as may be required based on the review of the security questionnaire form.

The contractor shall review all forms/documents to ensure each is complete, accurate and meets all DOJ requirements, including applicable residency and citizenship requirements. The contractor shall resolve any issues or discrepancies with the contractor employee, including resubmission of corrected forms or documentation. Completed forms/documents shall be submitted to the SPM (or designee, which may include the COR) within five (5) calendar days after being finalized.

(c) Adjudication and Pre-Employment Background Investigation Waivers

(1) Except as set forth in this section, background investigations must be conducted and favorably adjudicated for each contractor employee prior to commencing their work on this contract. Where programmatic needs do not permit the federal government to wait for completion of the entire background investigation, a pre-employment background investigation waiver for public trust contractors can be granted by the SPM, in consultation with the cognizant COR. Pre-employment waivers cannot be used to circumvent delays in clearing classified contractors through the DCSA, if access to classified information is required.

(2) As directed by the SPM, the contractor shall initiate pre-employment waivers for Public Trust Positions when necessary. This may entail performing credit history checks and submission of these checks as part of the security package, including satisfactory resolution of any issues prior to submission to the federal government. A waiver will be disapproved if it develops derogatory information that cannot be resolved in the contractor employee's favor. When a waiver has been disapproved, the CO, in consultation with the SPM and COR, will determine (i) whether the contractor employee will no longer be considered for work on a DOJ contract or (ii) whether to wait for the completion and favorable adjudication of the background investigation before the contractor employee commences work on a Department contract. The pre-employment background investigation waiver requirements include:

1. Verification of citizenship (copy of a birth certificate, naturalization certificate, or U.S. passport);
2. Verification of compliance with the *DOJ Residency Requirement* of this Clause;
3. Favorable review of the security questionnaire form;
4. Favorable FBI fingerprint results;
5. Favorable credit report;
6. Favorable review of the OF-306 form, Declaration for Federal Employment;
7. Verification of the initiation of the appropriate background investigation (for long-term personnel); and
8. Receipt of the signed DOJ Self-Reporting Requirements for All Contractor Personnel (see Section 6, below).

(3) The investigating agency (DCSA) will provide the SPM with the results of each proposed contractor employee's Public Trust investigation. Upon receipt of the investigation and any other pertinent documents from the investigating agency, the SPM will determine whether each proposed contractor employee should be granted employment security approval.

(4) The COR will notify the contractor of the results of Public Trust background investigations as they are completed and adjudicated, including any individual who is found ineligible for employment security approval. For any individual found ineligible for employment on a Department contract, the contractor shall propose a replacement and initiate the background investigation process consistent with this clause.

5. Identity Proofing and Badging

(a) Access to DOJ Information, federally-controlled IT systems, and/or unescorted access to federally-controlled facilities or space (regardless of whether the contractor employee will be issued a DOJ PIV card or building access badge) shall be made available after each respective contractor employee has (1) met the identity proofing requirements outlined below, and (2) completed all other security requirements stated elsewhere in this contract.

(b) (1) Public Trust contractor employees must appear in person at least once before a DOJ official or an official of a trusted contract company (i.e., has a facility security clearance) who is responsible for checking two forms of identification in original form prior to commencement of work by the contractor employee and PIV card or building access badge

issuance (as applicable). Approval will be documented by the DOJ official or an official of a trusted contract company. (Acceptable documents are listed in Form I 9, Employment Eligibility Verification, and at least one document must be a valid state or federal government issued picture ID).

(c) [Reserved]

(d) All contractor employees requiring unescorted access to a DOJ controlled facility or space shall comply with the PIV card or building access badge requirements outlined below:

(i) When any contractor employee enters a DOJ building for the first time, he/she shall allow one hour for security processing and the creation and issuance of a building access badge. PIV cards require additional processing time and will not likely be issued on the same day.

(ii) Building access badges shall be subject to periodic review by the contractor employee's supervisor and checked against his/her personal identification. The contractor employees shall present themselves for the issuance of renewed badges when required by the government as scheduled by the COR or his/her designee. The contractor shall notify the COR when contractor employee badges are lost, and must immediately apply for reissuance of a replacement badge. The contractor shall pay for reissued building access badges at no cost to the government. It is the contractor employee's responsibility to return badges to the COR or his/her designee when a contractor employee is dismissed, terminated or assigned to duties not within the scope of this contract.

6. Employee Reporting Requirements

(a) All contractor employees must sign the DOJ Self-Reporting Requirements for All Contractor Personnel statement acknowledging and accepting the DOJ requirement that they immediately self-report certain information using the Department's iReport system. The COR or SPM will provide the Self-Reporting statement as well as a list of reportable information, which varies by position sensitivity designation, to the contractor employee before commencing work under the contract. If the contractor employee does not have access to the DOJ iReport System, the COR or SPM will provide a fillable form for the contractor employee to complete and submit.

(b) The COR and SPM will review the written report and documentation and make a determination regarding continued employment on a DOJ contract.

(c) DOJ reporting requirements are in addition to the DCSA reporting requirements and the contractor's internal reporting requirements.

7. Replacement Personnel

(a) The contractor shall make every effort to avoid costs to the government for security investigations for replacement of contractor employees, and in so doing shall ensure that otherwise satisfactorily performing and physically able contractor employees remain in contract performance for the duration of the contract. The contractor shall take all necessary steps to ensure that contractor personnel who are selected for assignment to this contract are professionally qualified and personally reliable, of reputable background and sound character, and able to meet all other requirements stipulated in the contract.

(b) The fact that the government performs security investigations shall not in any manner relieve the contractor of its responsibility to ensure that all contract personnel are reliable and of reputable background and sound character. Should a security investigation conducted by the government and/or a contractor's self-report or failure to self-report render ineligible a contractor employee, the contracting officer will determine whether the contractor has violated this clause. The contracting officer may direct the contractor, at its own expense, to remove and replace any contractor personnel who fails to comply with or violates applicable requirements of this contract. Such action may be taken at the government's direction without prejudice to its rights under any other provision of this contract, including termination for default, and the contractor may be held liable, at a minimum, for all reasonable and necessary costs incurred by the government to (i) provide coverage (performance) through assignment of individuals employed by the government or third parties in those cases where absence of contractor personnel would cause either a security threat or DOJ program disruption and (ii) conduct security investigations in excess of those which would otherwise be required.

(c) Nothing in this clause shall require the contractor to bear costs involved in the conduct of security investigations for replacement of a contractor employee who separates from the contractor of his/her own accord, is incapacitated, or is deceased.

(d) The contractor shall comply with the terms and conditions set forth under this clause and assumes all liability for failure to comply. The rights and remedies conferred upon the government by this clause are in addition to all and other rights and remedies pursuant to the contract and as established by law.

(End of Clause)

DOJ-05 Security of Department Information and Systems (APR 2026)

I. Applicability to Contractors and Subcontractors

Section 2839.102 of the Justice Acquisition Regulation (JAR), (48 C.F.R. § 2839.102), applies to this contract. Accordingly, all contractors are obligated to comply with all applicable DOJ security policies, directives, or guidance documents, including the security requirements in the provisions in this contract clause. This contract clause applies to all contractors and subcontractors, including cloud service providers ("CSPs"), and personnel of the contractors and subcontractors (hereinafter collectively, "Contractor") that may access, collect, store, process, maintain, use, share, retrieve, disseminate, transmit, or dispose of DOJ Information. The security requirements set forth herein are in addition to those required by the Federal Acquisition Regulation ("FAR"), and any other applicable laws, mandates, contract clauses, DOJ policies, directives or guidance documents and Executive Orders pertaining to the development and operation of Information Systems and/or the protection of Government Information. This clause does not alter or diminish any existing rights, obligations, or liability under any other civil and/or criminal law, rule, regulation, or mandate.

II. General Definitions

The following general definitions apply to this clause. Specific definitions also apply as set forth in other paragraphs.

A. **Authorization to Operate ("ATO")**, as defined in National Institute of Standards and Technology ("NIST") Special Publication ("SP") 800-37 Revision 2, is the official management decision given by a senior Federal official or officials to authorize operation of an information system and to explicitly accept the risk to agency operations (including mission, functions, image, or reputation), agency assets, individuals, other organizations, and the Nation based on the implementation of an agreed-upon set of security and privacy controls.

B. **Cloud Computing**, as defined in DOJ Order 0904 Cybersecurity Program, is a model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction. This cloud model is composed of five essential characteristics, three service models, and four deployment models in accordance with NIST SP 800-145.

C. **Covered Contract** is any contract, order or other agreement under which the contractor, or a subcontractor at any tier, including a cloud service provider, may access, collect, store, process, maintain, use, share, retrieve, disseminate, transmit, or dispose of DOJ Information (as defined below) in the course of providing a product or service to the Department, with the exception of acquisitions under the micro-purchase threshold.

D. **Covered Information System** means any information system used for, involved with, or allowing, the processing, storing, or transmitting of DOJ Information under a Covered Contract.

E. **Data** means recorded information, regardless of form or the media on which it may be recorded. The term includes technical data, computer software, and personally identifiable information (PII) (defined below). The term does not include information incidental to contract administration, such as financial, administrative, cost or pricing, or management information.

F. **DOJ Information**, as defined in DOJ Order 0904, means any Information that is owned, produced, controlled, protected by, or otherwise within the custody or responsibility of the DOJ, including, without limitation, information related to DOJ programs or personnel. It includes, without limitation, Information (1) provided by or generated for the DOJ, (2) managed or acquired by the Contractor for the DOJ in connection with the performance of the contract, and/or (3) acquired to perform the contract.

G. **Information**, as defined in DOJ Order 0904, is any communication or representation of knowledge such as facts, data, or opinions, in any form or medium, including textual, numerical, graphic, cartographic, narrative, or audiovisual. This includes any communication or representation of knowledge in an electronic format that allows it to be stored, retrieved, or transmitted.

H. **Information System**, means a discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information (44 U.S.C. 3502(8)).

I. **Personally Identifiable Information** ("PII"), as defined in the FAR 24.101, means information that can be used to distinguish or trace an individual's identity, either alone or when combined with other information that is linked or linkable to a specific individual. It includes but is not limited to common data elements such as names, addresses, dates of birth, and places of employment, to identity documents, Social Security numbers or other government-issued identifiers, precise location information, medical history, and biometric records. This definition covers all PII that is created by or becomes available to the contractor, including its employees, subcontractors, or affiliates, as a result of performing under this contract. PII, as supplementally defined in DOJ Order 0904, also includes information about an individual maintained by an agency, including, but not limited to, information related to education, financial transactions, medical history, and criminal or employment history and information, which can be used to distinguish or trace an individual's identity.

J. **Private Cloud**, as defined in NIST SP 800-145, is the deployment model for cloud infrastructure provisioned for exclusive use by a single organization comprising multiple consumers (e.g., business units). It may be owned, managed, and operated by the organization, a third party, or some combination of them, and it may exist on or off premises.

K. **Security Breach** means any security incident (as defined below) that directly relates to the loss of control, compromise, exfiltration, manipulation, unauthorized disclosure, unauthorized acquisition, unauthorized exposure or unauthorized access or any similar occurrence of any Covered Information System or any DOJ Information or any PII accessed by, retrievable from, processed by, stored on, or transmitted within, to or from any such system. This includes incidents where (1) a person other than an authorized user accesses or potentially accesses PII or DOJ Information or (2) an authorized user accesses or potentially accesses PII or DOJ Information for an unauthorized purpose.

a. **Potential Security Breach** (hereinafter, "Potential Breach") means any suspected, but unconfirmed security breach (as defined above).

b. **Confirmed Security Breach** (hereinafter, "Confirmed Breach") means any confirmed security breach (as defined above).

L. **Security Incident** means any occurrence that (1) may actually or imminently jeopardize, without lawful authority, the availability, integrity, authentication, confidentiality, or nonrepudiation of DOJ Information or a Covered Information System; or (2) may constitute a violation or imminent threat of violation of law, security policies, security procedures, or acceptable use policies.

a. **Potential Security Incident** means any suspected, but unconfirmed security incident (as defined above).

b. **Confirmed Security Incident** means any confirmed security incident (as defined above).

M. **Vulnerability**, as defined in DOJ Vulnerability Management Plan, and the OCIO Information Security Management Procedure, means a weakness or flaw discovered in the design of a system that, when exploited, may result in a loss of confidentiality, integrity, or availability of DOJ Information or an Information System.

III. Confidentiality and Non-Disclosure of DOJ Information

A. Preliminary and final contract deliverables and all associated working papers and material generated by the Contractor developed using DOJ Information, product, source code, and/or methods of operations, are the property of the U.S. Government and must be submitted to the Contracting Officer ("CO") or the CO's Representative ("COR") at the conclusion of the contract. The U.S. Government has unlimited data rights to all such deliverables and associated working papers and materials in accordance with FAR 52.227-14 (Rights in Data-General). The Contractor will define a method of monitoring the development activity to include any activity associated with DOJ Information, product, source code, and methods of operations. The data rights and development details shall be defined within the Contract.

If the Contractor intends to utilize its existing data, for which it has a patent or copyright, to develop a contract deliverable, it is incumbent upon the Contractor to negotiate with the CO the proper FAR Part 27 clauses in the contract to protect its existing data.

B. Pursuant to FAR 52.227-14(d)(2), all documents and data produced in the performance of this contract containing DOJ Information, product code, source code, and/or methods of operations are the property of the U.S. Government and, without the prior written permission of the CO, the Contractor shall neither reproduce nor release such information to any third-party at any time, including during performance or following expiration and/or termination of the contract.

C. Any DOJ Information made available to the Contractor under this contract shall be used only for the purpose of performance of this contract and shall not be divulged or made known in any manner to any persons except as may be necessary in the performance of this contract. In performance of this contract, the Contractor assumes responsibility for the protection of the confidentiality of all DOJ Information processed, stored, or transmitted by the Contractor. The Contractor shall comply with information security responsibilities and duties throughout the contract and after expiration/termination as appropriate per contract close-out activities. When requested by the CO (typically no more than annually), the Contractor shall provide a report to the CO identifying, to the best of the Contractor's knowledge and belief, the type, amount, and level of sensitivity of the DOJ Information processed, stored, or transmitted under the Contract, including an estimate of the number of individuals for whom PII has been processed, stored or transmitted under the Contract and whether such information includes social security numbers (in whole or in part).

IV. Compliance with Information Technology Security Policies, Procedures and Requirements

A. For all Covered Information Systems, in addition to any other applicable requirements, as set forth in Part I, the Contractor shall comply with the security requirements of the Federal Information Security Modernization Act of 2014 ("FISMA"), Privacy Act of 1974, E-Government Act of 2002, National Institute of Standards and Technology ("NIST") Special Publications ("SP"), including NIST SP 800-37, 800-53, and 800-60 Volumes I and II, Federal Information Processing Standards ("FIPS") Publications 140-2, 199, and 200, Federal Risk and Authorization Management Program ("FedRAMP"), DOJ IT Security Standards as amended, and OMB Memoranda relating to the security of information and/or Federal Information Systems.

B. In addition, for all Covered Information Systems, the Contractor shall comply with the following requirements, which are listed here only to highlight certain specific applicable requirements from one of the sources identified in the first paragraph of this Section. This is not an exhaustive list of all such requirements with which the Contractor is obligated to comply, and the omission of a requirement from this list should not be construed as negating the materiality of that requirement. These requirements and those in the authorities in the prior paragraph should be read together.

1. Limiting access to DOJ Information and Covered Information Systems to authorized users and to transactions and functions that authorized users are permitted to exercise.
2. Providing security awareness training at least annually to all Contractor employees and contractors involved with the Covered Contract. Such training shall include, but not be limited to, recognizing and reporting potential indicators of insider threats to users and managers of DOJ Information and Covered Information Systems.
3. Creating, protecting, and retaining, in accordance with applicable requirements but in any event at least until the expiration of the contract, Covered Information System audit records, reports, and supporting documentation to enable reviewing, monitoring, analysis, investigation, reconstruction, and reporting of unlawful, unauthorized, or inappropriate activity related to such Covered Information Systems and/or DOJ Information.
4. Maintaining authorizations to operate any Covered Information System.
5. Performing continuous monitoring on all Covered Information Systems, to include but not be limited to, collecting, reviewing, and analyzing appropriate logs and timely investigating security alerts and potential security incidents.
6. Establishing and maintaining baseline configurations and current inventories of Covered Information Systems, including hardware, software, firmware, and documentation, throughout the Information System Development Lifecycle, and establishing and enforcing security configuration settings for IT products employed in Covered Information Systems.
7. Ensuring appropriate contingency planning has been performed, including DOJ Information and Covered Information System backups.
8. Identifying Covered Information System users, processes acting on behalf of users, or devices, and authenticating and verifying the identities of such users, processes, or devices, using multifactor authentication or HSPD-12 compliant authentication methods as defined by NIST 800-63-3, Digital Identity Guidelines or current revision.
9. Establishing and maintaining an operational incident handling capability for Covered Information Systems that includes adequate and timely development, logging, detection, analysis, containment, recovery, and user response activities, and tracking, documenting, and timely reporting incidents to appropriate officials and authorities within the Contractor's organization and the DOJ.
10. Performing periodic and timely maintenance on Covered Information Systems, and providing effective controls on tools, techniques, mechanisms, and personnel used to conduct such maintenance.
11. Protecting Covered Information System media containing DOJ Information, including paper, digital and electronic media, and DOJ assets under Contractor control; protecting them from environmental impacts, access, and equipment positioning requirements defined; limiting access to DOJ Information to authorized users; and sanitizing or destroying Covered Information System media containing DOJ Information before disposal, release or reuse of such media.

12. Limiting physical access to Covered Information Systems, equipment, and physical facilities housing such Covered Information Systems to authorized personnel according to DOJ 03.
13. Screening individuals prior to authorizing access to Covered Information Systems to ensure compliance with DOJ Security standards including personnel background checks.
14. Continuously assessing the risk to DOJ Information in Covered Information Systems, including scanning and remediating vulnerabilities, or implementing appropriate mitigation in accordance with DOJ policy, and ensuring the timely removal of assets no longer supported by the Contractor.
15. Continuously monitoring the application of security controls of Covered Information Systems, assessing the efficacy of such controls, and developing and implementing plans of action designed to correct deficiencies and eliminate or reduce vulnerabilities in such Covered Information Systems.
16. Monitoring, controlling, and protecting information transmitted or received by Covered Information Systems at the external boundaries and key internal boundaries of such Covered Information Systems, and employing architectural designs, software development techniques, and systems engineering principles that promote effective security.
17. Identifying, reporting, and correcting Covered Information System security flaws in a timely manner, providing protection from malicious code at appropriate locations, monitoring security alerts and advisories and taking appropriate and timely action in response.
18. Ensuring return of Government Furnished Equipment ("GFE") and/or PIV card assets within 10 business days of notification for end of use (contract end, staff change, etc.).
19. Complying with rights in data (FAR 52.227-14) as to the development, management, and protection of DOJ Information.
20. Reporting on risks or known issues impacting DOJ Services (staffing, hardware, process, changes, etc.) through the Contractor's CO or COR, DOJ Service Owner ("SO"), and Government Technical Manager ("GTM") including risk mitigation activities.
21. Reporting through the Contractor's CO or COR on any projected or planned changes in corporate ownership, covered information system design, and/or any technical changes that could impact the confidentiality, integrity or availability of DOJ Information, data, or systems. Changes to system design must be updated through the authorization process per NIST SP 800-37 Revision 2, Step 6 ('Continuous Monitoring') or current NIST revision.
22. When, as part of operating within the DOJ environment, the Contractor's covered information system is subject to review, audit, or assessment by third parties, facilitating DOJ access to information system resources, facilities, personnel, and documentation in a timely manner as required by the auditors. Should a third-party organization conduct a review of any Covered Information System, the Contractor must provide a copy of the report to DOJ, through the CO and COR.
23. To enhance software supply chain and transparency, upon request, the Contractor shall provide a current Software Bill of Materials (SBOM) for all software, software updates, modules, libraries, and container images delivered or operated in the performance of this contract, consistent with applicable federal policy such as the National Telecommunications and Information (NTIA)-established minimum elements for SBOM to the CO who will refer to the DOJ Cyber-Security Risk Management team (C-SCRM) [Authority: OMB M-26-05; EO 14028/ NTIA minimum requirements].
24. Reporting on outages impacting DOJ Services through the Contractor's CO, COR, and DOJ Service Owner (SO) to include event and mitigation details.

C. The Contractor shall not process, store, or transmit DOJ Information using a Covered Information System without first obtaining an ATO for each Covered Information System. The ATO shall be signed by the Authorizing Official for the DOJ component responsible for maintaining the security, confidentiality, integrity, and availability of the DOJ Information under this contract. (For Cloud Computing Systems, see Section V, below.)

D. The Contractor shall ensure compliance with DOJ-03 (Personnel Security Requirements for Contractor Employees) as to all Covered Information Systems.

E. When requested by the DOJ CO or COR as described below, the Contractor shall provide DOJ, including the Office of Inspector General ("OIG") and Federal law enforcement components, (1) access to any and all information and records, including electronic information, regarding a Covered Information System, and (2) physical access to the Contractor's facilities, installations, systems, operations, documents, records, and databases. Such access may include independent validation testing of controls, system penetration testing, and FISMA data reviews by DOJ or agents acting on behalf of DOJ, and such access shall be provided within 72 hours of the request. Additionally, the Contractor shall cooperate with DOJ's efforts to ensure, maintain, and safeguard the security, confidentiality, integrity, and availability of DOJ Information.

F. The use of Contractor-owned laptops or other portable digital or electronic media to process or store DOJ Information covered by this clause or access a Covered Information System is prohibited unless the CO approves it in writing after the Contractor has provided a letter certifying compliance with the following requirements. For any requirements which include the use or storage of PII, the Senior Component Official for Privacy must also approve. Any additional requirements set forth for the use or storage of PII under DOJ-02, Contractor Privacy Requirements, are in addition to, not superseded by, the requirements set forth here.

1. Media must be encrypted using a NIST FIPS 140-2 approved product.
2. The Contractor must develop and implement a process to ensure that security and other applications software is kept up to date.
3. Where applicable, media must utilize antivirus software and a host-based firewall mechanism.
4. The Contractor must log all computer-readable data extracts from databases holding DOJ Information and verify that each extract including such data has been erased within 90 days of extraction or that its use is still required. All DOJ Information should be treated by the Contractor as sensitive information unless specifically designated as non-sensitive by the DOJ.
5. A Rules of Behavior (ROB) form must be signed and acknowledged annually by users. These rules must address, at a minimum, authorized, and official use, prohibition against unauthorized users and use, and the protection of DOJ Information. The form also must notify the users that they have no reasonable expectation of privacy regarding any communications transmitted through or data stored on Contractor-owned laptops or other portable digital or electronic media.
6. Cybersecurity Awareness Training (CSAT) shall be provided annually by Contractor for all users of Covered Information System. This training must be submitted to, and approved by, the CO or COR in advance of being provided to users. Users must complete and acknowledge having received CSAT each year. At a minimum, CSAT provided by contractors must include:
 - a. Insider Threat Detection and Reporting – Importance of detecting, methodologies, indicators, and reporting
 - b. Privacy Awareness – Privacy Act and PII
 - c. General Cybersecurity – Information security, trends in advance persistent threats, social engineering/phishing, appropriate use, mobile devices, remote access, basic security best practices

G. Contractors shall not store DOJ information on Contractor-owned removable IT (e.g., media such as a thumb drive or external hard drive) unless expressly authorized in writing by the DOJ CO or COR in the performance of their contract.

H. When no longer needed, all media must be processed (sanitized, degaussed, or destroyed) in accordance with NIST SP 800-88, Guidelines for Media Sanitization.

I. The Contractor must keep an accurate inventory of digital or electronic media used in the performance of DOJ contracts.

J. The Contractor must remove all DOJ Information from Contractor media and return all such information to the DOJ within 10 days of the expiration or termination of the contract, unless otherwise extended by the CO, or waived (in part or whole) by the CO, and all such information shall be returned in a format and form acceptable to DOJ. The Contractor shall provide a written certification certifying the removal and return of all such information to the CO within 10 business days of the removal and return of all DOJ Information.

K. DOJ, at its discretion, may suspend the Contractor's access to any DOJ Information, or terminate the contract, when DOJ suspects that the Contractor has failed to comply with any security requirement, or in the event of an Information System Security Incident or Security Breach (see definitions above), where the Department determines that either event gives cause for such action. The suspension of access to DOJ Information may last until such time as DOJ, in its sole discretion, determines that the situation giving rise to such action has been corrected or no longer exists. Any termination action taken because of the Contractor's suspected failure to comply with any security requirement will be conducted in accordance with the applicable termination clause governing the awarded contract. The Contractor understands that any suspension or termination in accordance with this provision shall be at no cost to DOJ, and that upon request by the CO, the Contractor must immediately return all DOJ Information to DOJ, as well as any media upon which DOJ Information resides, at the Contractor's expense. The Contractor must comply with FAR 52.227-14 (Rights in Data), FAR 52.245-1 (Government Property), DOJ 2400.3A Chapter 1 (component property procedures), and FAR 4.804-5(a)(6) (Procedures for closing out contract files).

V. Cloud Computing

A. The Contractor may not utilize the Cloud system of any Cloud Service Provider ("CSP") unless:

1. All of the following has occurred: (a) the Cloud system and CSP have been evaluated by a Third Party Assessing Organization ("3PAO") certified under FedRAMP; (b) the Cloud system received FedRAMP authorization; (c) the Contractor has provided the most current System Security Plan ("SSP") and Security Assessment Report ("SAR") to the DOJ CO for consideration, and provides any subsequent SSPs and SARs within 30 days of issuance; and, (d) the Authorizing Official for the DOJ component responsible for maintaining the security confidentiality, integrity, and availability of the DOJ Information under the Covered Contract has issued an ATO; or,
2. In cases where the CSP or its offering is not FedRAMP authorized, the COR approves utilization of the Cloud System after the CSP has worked with the authorizing official, the DOJ OCIO, and the FedRAMP Program Management Office to determine that the CSP is likely to seek and receive Agency/FedRAMP authorization within 1 year, or DOJ has authorized use as a Private Cloud or Contractor Owned, Contractor Operated system.

B. The Contractor must ensure that the CSP allows DOJ to access and retrieve any DOJ Information processed, stored, or transmitted in a Cloud system under this Contract within a reasonable time of any such request, but in no event less than 48 hours from the request. To ensure that the DOJ can fully and appropriately search and retrieve DOJ Information from the Cloud system, access shall include any schemas, meta-data, and other associated data artifacts.

C. The Contractor must ensure that the CSP provides access and information to support and enable DOJ's cloud security posture management, to include the current inventory of security management configuration data for services and information to confirm the Contractor has been monitoring accounts for compliance with security requirements. The DOJ Justice Security Operations Center (JSOC) must be able to access logs and events to investigate potential security breaches and perform security posture assessments associated with the Security Audit Identity Credential Access Management (ICAM) policies.

D. The Contractor must ensure that the CSP provides evidence of annual recertification of privileged user access management.

E. A C-SCRM review is mandatory for specified acquisitions in accordance with established process in EO 14028 and NIST SP 800-161, Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations, or superseding document. All vendor products and solutions to be used on DOJ national security systems, enterprise-wide systems, or new FIPS-199 High and Moderate systems for the purpose of accessing, collecting, storing, processing, maintaining, using, sharing, retrieving, disseminating, transmitting, or disposing of DOJ Information must be submitted to DOJ OCIO for a C-SCRM review prior to contract award or ATO signature. Changes in corporate ownership or structure shall be reported to the CO for referral to C-SCRM. The Contractor shall notify the CO of any confirmed Supply Chain compromise affecting the Contractor's products or services within 1 hour of discovery.

☒ The following C-SCRM requirements for acquisition of systems, hardware, or software which will be used in systems that are mission critical or process sensitive data apply to this award. **(CO check as appropriate in coordination with the Program Manager and/or System Owner)**

1. The Contractor shall develop and deliver a C-SCRM Plan. The C-SCRM Plan shall meet the format described in NIST SP 800-161, Appendix E. The C-SCRM plan shall address the following security controls from NIST SP 800-53 Rev 5: SR-2, SR-3, SR-4, SR-5, SR-6, SR-7, SR-8, SR-9, SR-10, and SR-11. Equivalent ISO 27000 series controls may be used if they are mapped to the NIST control(s).
2. The Contractor shall implement the required security controls as documented in the C-SCRM Plan. The requirements of the C-SCRM plan shall flow down to all subcontractors. Evidence of the certification and compliance is required.
3. For cloud platforms or managed services, upon request, the Contractor shall provide a current SBOM of the runtime production environment reflecting the software components and dependencies materially present in the service.
4. The Contractor shall provide evidence of compliance with the documented C-SCRM Plan. (CO select which applies)

☒ Self-assessment by a contractor security team

☐ External assessment by an independent auditor

VI. Information System Security Incident

A. Confirmed Security Incident. The Contractor shall immediately (and in no event later than 1 hour of discovery) report any Confirmed Security Incident to the DOJ CO and COR. If the Confirmed Security Incident occurs outside of regular business hours and/or neither the DOJ CO nor the COR can be reached, the Contractor must call JSOC at 1-202-357-7000 immediately (and in no event later than within 1 hour of discovery of the Confirmed Security Incident) and shall notify the CO and COR as soon as practicable.

B. Potential Security Incident.

1. If the Contractor suspects that DOJ information has been potentially disclosed or impacted, the Contractor shall promptly investigate to determine if a Security Incident has occurred. If the Contractor has not determined within 24 hours (i.e., 24 hours from detection of potential security incident and/or security breach) whether the Potential Security Incident was in fact a Security Incident, then it must immediately report the Potential Security Incident to the DOJ CO and the COR. If the time by which to report the Potential Security Incident occurs outside of regular business hours and/or neither the DOJ CO nor the COR can be reached, the Contractor must call or e-mail the JSOC Team at 1-202-357-7000 or JSOC@USDOJ.GOV and contact the DOJ CO and COR as soon as practicable. If the contract involves PII, the Contractor must comply with the notification requirements of DOJ-02 and Executive Order M-17-12 (Memorandum on Preparing for and Responding to a Breach of Personally Identifiable Information), Contractor Privacy Requirements, Section B.5, for an actual or suspected Security Incident.
2. The Contractor must limit sharing of Security Incident details to only those individuals involved in responding to the potential Security Incident. Any provisions of the Covered Contract regarding the citizenship or location of individuals working on the Covered Contract apply equally to individuals involved in responding to any potential Security Incidents. The Contractor may request assistance from the JSOC for advice, incident response, or FBI coordination. The Contractor must provide weekly updates to CO, COR and JSOC during the course of a Security Incident investigation.

C. Any report submitted in accordance with paragraphs (B) and (C), above, shall identify:

1. Both the Covered Information Systems and DOJ Information involved or at risk, including the type, amount, and level of sensitivity of the DOJ Information and, if the DOJ Information contains PII, the estimated number of unique instances of PII.
2. All steps and processes being undertaken by the Contractor to minimize, remedy, and/or investigate the Security Incident.
3. Any and all other information as required by the CISA Federal Incident Notification Guidelines, including the functional impact, information impact, impact to recoverability, threat vector, mitigation details, and all available incident details; and

The Contractor may request assistance from the JSOC Team for advice, incident response, or FBI coordination, and must provide weekly updates to CO, COR, and JSOC during the course of an Incident investigation.

D. Except as otherwise required by Federal, State and local laws, executive orders, rules and regulations, all determinations regarding whether and when to notify other individuals and/or federal agencies potentially affected by a Security Incident will be made by DOJ senior officials, the DOJ Core Management Team, or the COR at DOJ's discretion.

E. The Contractor must provide to DOJ full access to any facility and/or Covered Information System affected or potentially affected by any potential or confirmed Security Incident, including access by the DOJ OIG and federal law enforcement organizations, and undertake any and all response actions DOJ determines are required to ensure the protection of DOJ Information, including providing all requested images, log files, and event information to facilitate rapid resolution of any Security Incident.

F. DOJ, at its sole discretion, may obtain, and the Contractor will permit, the assistance of other federal agencies and/or third-party contractors or firms to aid in response activities related to any potential or confirmed Security Incident. Additionally, DOJ, at its sole discretion, may require the Contractor to retain, at the Contractor's expense, a 3PAO acceptable to DOJ, with expertise in incident response, compromise assessment, and federal security control requirements, to conduct a thorough vulnerability and security assessment of all affected Covered Information Systems.

G. Response activities related to any Security Incident undertaken by DOJ, including activities undertaken by the Contractor, other federal agencies, and any third-party contractors or firms at the request or direction of DOJ, may include inspections, investigations, forensic reviews, data analyses and processing, and final determinations of responsibility for the Security Incident and/or liability for any additional response activities. The Contractor shall be responsible for all costs and related resource allocations required for all such response activities related to any Security Incident, including the cost of any penetration testing.

VII. **Pass-Through of Security Requirements to Subcontractors and CSPs**

A. The requirements set forth in the preceding paragraphs of this clause apply to all subcontractors and CSPs who perform work in connection with the contract, including any CSP providing services for any other CSP under the contract, and the Contractor shall flow down this clause to all subcontractors and CSPs performing under this contract. Any breach by any subcontractor or CSP of any of the provisions set forth in this clause will be attributed to the Contractor.

(End of Clause)

DOJ-07 Prohibition On Access By Non-U.S. Citizens To DOJ IT Systems (MAR 2002)

The Department of Justice does not permit the use of Non-U.S. citizens in the performance of this contract or commitment for any position that involves access to or development of any DOJ IT system. By signing the contract or commitment document, the contractor agrees to this restriction. In those instances where other non-IT requirements contained in the contract or commitment can be met by using Non-U.S. citizens, those requirements shall be clearly described.

(End of Clause)

DOJ-08 Continuing Contract Performance During a Pandemic Influenza or other National Emergency (OCT 2007)

During a Pandemic or other emergency we understand that our contractor workforce will experience the same high levels of absenteeism as our federal employees. Although the Excusable Delays and Termination for Default clauses used in government contracts list epidemics and quarantine restrictions among the reasons to excuse delays in contract performance, we expect our contractors to make a reasonable effort to keep performance at an acceptable level during emergency periods.

The Office of Personnel Management (OPM) has provided guidance to federal managers and employees on the kinds of actions to be taken to ensure the continuity of operations during emergency periods. This guidance is also applicable to our contract workforce. Contractors are expected to have reasonable policies in place for continuing work performance, particularly those performing mission critical services, during a pandemic influenza or other emergency situation.

The types of actions a federal contractor should reasonably take to help ensure performance are:

- Encourage employees to get inoculations or follow other preventive measures as advised by the public health service.
- Contractors should cross-train workers as backup for all positions performing critical services. This is particularly important for work such as guard services where telework is not an option.
- Implement telework to the greatest extent possible in the workgroup so systems are in place to support successful remote work in an emergency.
- Communicate expectations to all employees regarding their roles and responsibilities in relation to remote work in the event of a pandemic health crisis or other emergency.
- Establish communication processes to notify employees of activation of this plan.
- Integrate pandemic health crisis response expectations into telework agreements.
- With the employee, assess requirements for working at home (supplies and equipment needed for an extended telework period). Security concerns should be considered in making equipment choices; agencies or contractors may wish to avoid use of employees' personal computers and provide them with PCs or laptops as appropriate.
- Determine how all employees who may telework will communicate with one another and with management to accomplish work.
- Practice telework regularly to ensure effectiveness.
- Make it clear that in emergency situations, employees must perform all duties assigned by management, even if they are outside usual or customary duties.
- Identify how time and attendance will be maintained.

It is the contractor's responsibility to advise the government contracting officer if they anticipate not being able to perform and to work with the Department to fill gaps as necessary. This means direct communication with the contracting officer or in his/her absence, another responsible person in the contracting office via telephone or email messages acknowledging the contractor's notification. The incumbent contractor is responsible for assisting the Department in estimating the adverse impacts of nonperformance and to work diligently with the Department to develop a strategy for maintaining the continuity of operations.

The Department does reserve the right in such emergency situations to use federal employees, employees of other agencies, contract support from other existing contractors, or to enter into new contracts for critical support services. Any new contracting efforts would be acquired following the guidance in the Office of Federal Procurement Policy issuance "Emergency Acquisitions", May, 2007 and Subpart 18.2. Emergency Acquisition Flexibilities, of the Federal Acquisition Regulations.

(End of Clause)

DOJ-09 Large Language Models (MAR 2026)

(a) Definitions.

1. "Large language model" (LLM) means a generative Artificial Intelligence (AI) model trained on vast, diverse datasets that enable the model to generate natural-language responses to user prompts.
2. "Restricted Intellectual Property" means computer code (whether machine readable or written in a programming language) and model weighting information.

(b) Compliance with Unbiased AI Principles. Any LLM provided under this contract, including an LLM integrated into another software product or service, must adhere to the Unbiased AI Principles, truth-seeking and ideological neutrality, as set forth in Executive Order 14319, *Preventing Woke AI in the Federal Government* (July 23, 2025).

(c) End-User Feedback. LLMs provided under this contract must provide a meaningful option for an end-user to submit feedback and provide notice on outputs, including those that violate the Unbiased AI Principles (such as a general inbox, specific product point of contact, or similar mechanism).

(d) Disclosure Obligations. The Offeror (or, in the event of an existing contract, the Contractor) must clearly disclose any planned or potential provision of an LLM as part of the Offer (or, in the event of an existing contract, in a separate disclosure provided within ten days of the date on which this clause is incorporated into the contract). This disclosure must include the following information:

1. The LLM acceptable use policy;
2. LLM model, system, and/or data cards, ordinarily including summaries of the training process, identified risks and mitigations, and model evaluation scores on LLM benchmarks;
3. Architecture decision records, application programming interface documentation and specifications, data lineage and dataset descriptions;
4. Development artifacts including contextual documentation, project blueprints and boilerplates;
5. Process and governance artifacts including product requirements documents, traceability reports, security checklists and risk assessments, and evaluation and test results;
6. Explanation of the proposed user-interface and user-experience (human-centered) design approach,
7. If the proposed LLM utilizes model merging or model blending, documentation of details on this process,
8. Key characteristics including format, version control, purpose, and proposed evaluation and quality assurance plans;
9. Recommended architectural and data workflow diagrams on where the proposed model would reside, how the model would address data inputs and outputs, and what connections and safeguards it hosts in relation to other versions, models, or iterations external to the proposed model residence;
10. End-user resources for the LLM (e.g., product tutorials, developer guides, or other best tools to help customers ensure proper use of the LLM and maximize utility);
11. Details regarding the mechanism(s) for end user feedback; and
12. Any additional information identified as necessary to assess compliance with the Unbiased Principles either explicitly required in the solicitation or, for existing contracts, in an agency request.

Nothing in this paragraph shall require the Offeror to disclose Restricted Intellectual Property.

(e) Materiality of Performance. The requirements stated in this section are material to eligibility, performance, and payment under the contract. In the event that the Contracting Officer notifies the Contractor that an LLM provided under this contract fails to comply with the provisions of this section, and the Contractor fails to cure the violation within a reasonable period, the Department shall be entitled to terminate the contract for default (or in the case of a commercial contract, for cause) and the Contractor shall be responsible for all resulting costs and other damages, including those associated with decommissioning the LLM.

(f) Subcontractor Obligations. The requirements in this section shall be flowed-down to and shall apply to LLMs provided by subcontractors at all tiers.

(End of Clause)

[END OF ADDENDUM TO FAR 52.212-4]

Section 3 - List of Attachments

Identifier	Title	Number of Pages
1	Statement of Work.pdf	15
2	Sample Data	

Section 4 - Solicitation Provisions

A.2 ADDENDUM TO FAR 52.212-1, Instructions to Offerors-Commercial Products and Commercial Services (Sep 2023) (DEVIATION NOV 2025)

The terms and conditions for the following provisions are hereby incorporated into this solicitation as an addendum to FAR provision 52.212-1.

Provisions By Reference

52.252-1 SOLICITATION PROVISIONS INCORPORATED BY REFERENCE (FEB 1998)		
This solicitation incorporates one or more solicitation provisions by reference, with the same force and effect as if they were given in full text. Upon request, the Contracting Officer will make their full text available. The offeror is cautioned that the listed provisions may include blocks that must be completed by the offeror and submitted with its quotation or offer. In lieu of submitting the full text of those provisions, the offeror may identify the provision by paragraph identifier and provide the appropriate information with its quotation or offer. Also, the full text of a solicitation provision may be accessed electronically at this/these address(es): www.acquisition.gov		
Provision	Title	Fill-ins (if applicable)
52.204-7 (DEV)	System for Award Management-Registration (Nov 2024) (DEVIATION NOV 2025)	
52.212-1 (DEV)	Instructions to Offerors-Commercial Products and Commercial Services (Sep 2023) (DEVIATION NOV 2025)	
52.212-2 (DEV)	Evaluation-Commercial Products and Commercial Services (Nov 2021) (DEVIATION NOV 2025)	Evaluation Factors : "technical, price, and past performance."
52.240-90 (DEV)	Security Prohibitions and Exclusions Representations and Certifications (DEVIATION NOV 2025)	

Provisions By Full Text

2852.233-70 Protests Filed Directly with the Department of Justice (NOV 2020)

(a) The following definitions apply in this provision:

(1) "Agency Protest Official" (APO) means the Deciding Official for a procurement protest filed with a contracting activity of DOJ when the contracting officer will not be the Deciding Official because of the protestor's election under JAR 2833.103(b)

(2) "Deciding Official" means the official who will review and decide a procurement protest filed with the agency. The Deciding Official will be the contracting officer unless the protestor requests pursuant to JAR 2833.103(b) that the protest be decided by an individual above the level of the contracting officer, in which case the HCA will designate an APO to serve as the Deciding Official.

(3) "Interested Party" means an actual or prospective offeror whose direct economic interest would be affected by the award of a contract or by the failure to award a contract.

(b) Only interested parties may file a protest.

(c) An interested party filing a protest with the DOJ has the choice of requesting either that the Contracting Officer or the APO decide the protest.

(d) A protest filed directly with the DOJ shall:

- (1) Indicate that it is a protest to DOJ.
- (2) Be filed with the Contracting Officer.
- (3) State whether the protestor chooses to have the Contracting Officer or the Agency Protest Official decide the protest. If the protestor is silent on this matter, the Contracting Officer will decide the protest.
- (4) Indicate whether the protestor prefers to make an oral or written presentation of arguments in support of the protest to the deciding official.
- (5) Include the information required by FAR 33.103(d)(2):
 - (i) Name, address, facsimile number and telephone number of the protestor.
 - (ii) Solicitation or contract number.
 - (iii) Detailed statement of the legal and factual grounds for the protest, to include a description of resulting prejudice to the protestor.
 - (iv) Copies of relevant documents.
 - (v) Request for a ruling by the agency.
 - (vi) Statement as to the form of relief requested.
 - (vii) All information establishing that the protestor is an interested party for the purpose of filing a protest.
 - (viii) All information establishing the timeliness of the protest.

(e) The decision by the APO is an alternative to a decision by the Contracting Officer. The APO will not consider appeals from the Contracting Officer's decision on an agency protest and a decision by the APO is final and not appealable.

(f) The Deciding Official may conduct a scheduling conference. The scheduling conference, if conducted, will establish deadlines for oral or written arguments in support of the agency protest and for agency officials to present information in response to the protest issues. The deciding official may hear oral arguments in support of the agency protest at the same time as the scheduling conference, depending on availability of the necessary parties.

(g) Oral conferences may take place either by telephone or in person.

(h) The protestor has only one opportunity to support or explain the substance of its protest. DOJ procedures do not provide for any discovery. The deciding official may request additional information from the agency or the protestor. The deciding official will resolve the protest through informal presentations or meetings to the maximum extent practicable.

(i) A protestor may represent itself or be represented by legal counsel. The DOJ will not reimburse the protester for any legal fees related to the agency protest.

(j) The DOJ will stay award or suspend contract performance in accordance with FAR 33.103(f), unless the contract award is justified, in writing, for urgent and compelling reasons or is determined, in writing, to be in the best interest of the Government. The justification or determination shall be approved at a level above the Contracting Officer. The stay or suspension, unless over-ridden, remains in effect until the protest is decided, dismissed, or withdrawn.

(k) The deciding official will make a best effort to issue a decision on the protest within thirty-five (35) days after the filing date. The decision shall be written, and provided to the protestor using a method that provides for evidence of receipt.

(l) The DOJ may dismiss or stay proceedings on an agency protest if a protest on the same or similar basis is filed with a forum outside DOJ.

(End of Clause)

4.1 Instructions to Quoters

Quotation Format

Quotations shall consist of the following:

Volume I – Technical Quotation

The technical quotation shall not exceed ten (10) pages and shall include:

1. Understanding of the requirement.
2. Proposed methodology for analyzing Government-furnished historical medical claims data.
3. Identification of any commercial AI or analytical tools proposed.
4. Quality control procedures to ensure analytical accuracy.

5. Brief project schedule demonstrating completion within the required performance period.

Volume II – Past Performance

Provide up to two (2) examples of similar work performed within the last five years, including customer, contract or purchase order number (if available), period of performance, description, and point of contact (if available). Quoters without relevant past performance may state that no relevant past performance exists.

Volume III – Price

Submit one firm-fixed-price quotation for the complete requirement (CLIN 0001).

4.2 Evaluation Factors for Award

Basis for Award

The Government intends to award a single firm-fixed-price purchase order. Award will be made on a best-value basis considering the evaluation factors below. The Government reserves the right to award without conducting exchanges.

Evaluation Factors

1. Technical Approach
2. Past Performance
3. Price

Technical Approach and Past Performance, when combined, are approximately equal to Price.

Technical Approach

The Government will evaluate the extent to which the quotation demonstrates:

1. Understanding of the requirement.
2. A sound methodology for performing the historical medical claims analysis.
3. Appropriate use of commercial analytical and AI technologies.
4. Reasonable quality control procedures.
5. Ability to complete performance within the required timeframe.

The Government will not assign adjectival ratings but will evaluate the relative merits of each quotation.

Past Performance

The Government will evaluate recent and relevant past performance to assess the likelihood of successful performance. Quoters with no relevant past performance will receive a neutral evaluation.

Price

Price will be evaluated for fairness and reasonableness using appropriate price analysis techniques.

Best-Value Determination

The Government will perform an integrated assessment of Technical Approach, Past Performance, and Price. Award may be made to other than the lowest-priced quoter if the additional value justifies the price premium, or to the lowest-priced quoter if any additional technical merit does not warrant additional cost.

[END OF ADDENDUM TO FAR 52.212-1]

STATEMENT OF WORK (SOW)

Historical Medical Claims Data Analysis

Federal Bureau of Prisons (FBOP)

Health Services Division / Information Technology and Data Division

Document Field	Value
Document Type	Statement of Work
Program	Historical Medical Claims Data Analysis
Estimated Value	Not specified in this SOW
Period of Performance	60 days from provision of data (see Section 4.0)
Primary Objective	One-time analysis of historical outside medical claims data to identify fraud, waste, and abuse, and to identify billing and utilization trends, using a closed-gap artificial intelligence system

Table of Contents

1.0 Background.....	3
2.0 Purpose	3
3.0 Scope.....	3
4.0 Period of Performance.....	4
5.0 Place of Performance	4
6.0 Task Requirements	4
7.0 Deliverables	4
8.0 Government Furnished Equipment/Information (GFE/GFI).....	5
9.0 Security	5
9.1 System Security Requirements	5
9.2 Security and Clearance Requirements	5
9.3 Systems Security	6
9.4 Data Security.....	7
10.0 Earned Value Management.....	8
11.0 Inspection and Acceptance of Deliverables	8
12.0 Payment and Invoicing	8
Appendix A	15

1.0 Background

The Federal Bureau of Prisons (BOP) is a federal law enforcement agency within the Department of Justice (DOJ). The BOP is responsible for the care, custody, and control of approximately 154,000 federal offenders, both male and female, 139,000 of which are confined in 118 institutional facilities throughout the United States, including Hawaii and Puerto Rico. The BOP also has 6 regional offices, a Central Office (headquarters), 2 staff training centers, and 22 Residential Reentry Management offices.

The BOP provides healthcare to those 154,000 inmates in the prisons (facilities) geographically dispersed throughout the contiguous United States, Hawaii, and Puerto Rico. Medical services rendered to all federal inmates are governed by Federal law, BOP policies and procedures, and American Correction Association (ACA) standards. Medical services are rendered by health services departments within each facility as appropriate. Medical services that cannot be rendered within an institution are rendered within the community via comprehensive medical services contracts which serve as overarching contracts to provide for a full range of acute and sub-specialty care needs BOP inmates may have.

The BOP's Health Services Division (HSD) is responsible for providing essential health care services consistent with community standards to these inmates. HSD's health care mission is to deliver medically necessary health care to inmates effectively in accordance with proven standards of care without compromising public safety concerns inherent to BOP's overall mission.

BOP's electronic medical record (BEMR) is the computerized information system supporting HSD's health care mission. BEMR is the main repository and authoritative source of medical data for inmate medical care. BEMR is a complete electronic health record designed exclusively for corrections and customized to meet the BOP's unique requirements. BEMR spans all disciplines including medical, dental, mental health and pharmacy services; and BEMR is deployed exclusively at 100% of the BOP facilities.

2.0 Purpose

The BOP has a requirement to analyze granular line-item level claims data from comprehensive medical services vendors. The analysis required will utilize historical claims data provided by the BOP to the vendor. This data will be provided by BOP to the vendor in a .csv file format and includes elements such as: claim ID, patient gender, BOP internal one time use unique patient ID, authorization number, payor/institution information (name, city, state), diagnostic codes, service dates, procedure (CPT) codes, procedure description, charge amount, billing provider information (NPI, ID number, name), providing facility information (name, NPI). The purpose of this analysis will be to examine the data for fraud, waste, and abuse; as well as to identify trends within the claims data such as over-use or over-billing including duplicate charges. Output results should be provided in MS-Word and/or MS-Excel file formats or other structured file formats suitable for analysis. No current real-time data will be provided as this analysis is solely intended for historical evaluation. Additionally, no personally identifiable information (PII) will be provided in the dataset. This requirement is specifically for an analysis utilizing a closed-gap artificial intelligence (AI) system to perform the analytical work. Specifically, no public or otherwise open LLM shall be used. No BOP data shall be sent to any third-party providers including external commercial generative AI providers. Prior to contract award vendor must disclose all AI models intended for use in the analysis to ensure no restricted or unauthorized models are used.

3.0 Scope

The BOP has a requirement for a one-time analysis of a dataset of medical claims consisting of 666,000 rows of data corresponding to claims from 1/1/2021 through 12/31/2025 for services provided under the auspices of comprehensive medical contracts. The outcome of this analysis will provide the BOP with information regarding fraud, waste, and abuse in the historical claims data provided. All data will be provided by the BOP to the vendor. The contractor shall be responsible for providing the system solution that meets and/or exceeds the system requirements defined in this statement of work (SOW) and shall include the use of a close-gap artificial intelligence system.

4.0 Period of Performance

Analysis of the data provided should be completed within 60 days of provision of data.

Any corrections, additions or omissions made to the contractor's submitted project management plans shall be submitted to the HSD project manager and the BOP COR supporting this effort prior to enterprise and facility implementation.

5.0 Place of Performance

The contractor shall comply with all applicable state and federal laws, codes, regulations, and standards governing the facility operations for BOP facilities. The work for this project may be completed outside any BOP property and final work product delivered electronically to the BOP.

6.0 Task Requirements

The contractor shall be responsible for providing the system solution that meets and/or exceeds the system requirements defined in this statement of work (SOW) and shall include the use of a closed-gap artificial intelligence system.

This requirement is specifically for an analysis utilizing a closed-gap artificial intelligence (AI) system to perform the analytical work. Specifically, no public or otherwise open LLM shall be used. No BOP data shall be sent to any third-party providers including external commercial generative AI providers. Prior to contract award vendor must disclose all AI models intended for use in the analysis to ensure no restricted or unauthorized models are used.

The system used for the analysis must comply with BOP's Information Technology and Data Division (ITDD) security standards, adhere to all information security and health information technology state and federal regulatory mandates, and provide for management and mitigation of platform vulnerabilities.

The system solution shall not include long-term data storage and shall purge all BOP provided data at the conclusion of the required analysis once all reporting has been generated.

The contractor shall provide technical resources with the expert ability to support delivery of the services outlined in Section 3.0, Scope, Section 7.0, Deliverables, and Appendix A of this statement of work.

All requirements outlined in Section 3.0, Scope, Section 7.0, Deliverables, and Appendix A of this statement of work shall be included in the license, support, and maintenance fees noted in the contract and provided with no additional cost.

7.0 Deliverables

This statement of work is comprised of the following analysis deliverables to identify at a minimum:

Deliverable	Description	Schedule of Deliverable	Associated CLIN
Historical Medical Claims Data Analysis Report	Complete analysis of Government-furnished historical claims data including all required analyses.	60 days	0001
Duplicate Claims Analysis	Identification of duplicate claims.	60 days	0001
Diagnosis/Procedure Code Analysis	Identification of inappropriate procedure codes based on diagnosis codes.	60 days	0001
Provider Outlier Analysis	Identification of providers exhibiting overuse of specific procedure codes.	60 days	0001
Medicare Rate Comparison Report	Comparison of billed rates to Medicare reimbursement rates reported as a percentage of Medicare.	60 days	0001
Provider Ranking Report	Ranking of providers by total amount billed.	60 days	0001

Deliverable	Description	Schedule of Deliverable	Associated CLIN
Patient Ranking Report	Ranking of patients by total amount billed.	60 days	0001
Facility Ranking Report	Ranking of facilities by total amount billed.	60 days	0001
Procedure Code Ranking Report	Ranking of procedure codes by total amount billed.	60 days	0001
Provider by Procedure Code Report	Ranking of providers by procedure code utilization.	60 days	0001
Corrected Analysis	Corrections, additions, or omissions resulting from Government review.	60 days	0001
Final Documentation and Analysis Reporting	Final documentation and analytical reporting for ITDD/HSD acceptance and approval.	60 days	0001

Output results should be provided in MS-Word and/or MS-Excel file formats or other structured file formats suitable for analysis.

8.0 Government Furnished Equipment/Information (GFE/GFI)

All data required for this analysis will be provided by the BOP to the vendor.

This data will be provided by BOP to the vendor in a .csv file format and includes elements such as: claim ID, patient gender, BOP internal one time use unique patient ID, authorization number, payor/institution information (name, city, state), diagnostic codes, service dates, procedure (CPT) codes, procedure description, charge amount, billing provider information (NPI, ID number, name), providing facility information (name, NPI).

No current real-time data will be provided as this analysis is solely intended for historical evaluation. Additionally, no personally identifiable information (PII) will be provided in the dataset.

9.0 Security

The following security requirements apply to the contractor's personnel, systems, and handling of Government data under this statement of work.

9.1 System Security Requirements

The contractor shall provide security safeguards that are consistent with Health Insurance Portability & Accountability Act (HIPAA), 42 U.S.C. § 201.

9.2 Security and Clearance Requirements

All required contractor personnel shall have personnel security clearances commensurate with the Homeland Security Presidential Directive 12 (HSPD-12) for the highest level of information processed by the system(s) they use. The provisions of Department of Justice Order DOJ 2610.2C, Federal Bureau of Prisons Information Security Program Statement 1237.16 and the Federal Bureau of Prisons Human Resource Management Manual 3000.02D shall be followed to determine appropriate security clearance levels.

Contractor security clearances, including the submission of security clearance forms, etc., shall be coordinated with the COR prior to contract employee arrival at the BOP facility. As determined by the COR and/or Human Resource Security Specialist, clearances may require one or all of the following:

- National Crime Information Center (NCIC) check; DOJ-99 (name check);
- FD-258 (fingerprint check);
- Law Enforcement Agency checks;
- Vouchering of Employers over past five years; Resume/Personal Qualifications;

- OPM-329-A (Authority for Release of Information); NACI check (if applicable); and
- Urinalysis Test (for detection of marijuana and other drug usage).

Note: If it is determined that a urinalysis test is required, it will be administered at the closest BOP site. If a test is positive for drug usage, the assigned individual(s) shall be excluded from performance of work for this requirement, and subject to the same security requirements, the contractor shall provide acceptable replacement staff.

The contractor shall employ effective safeguards and security controls to ensure that information associated with the work is protected from loss, damage, computer viruses or other destructive incidents. The safeguards employed should ensure that materials and services are secured in a manner that prevents tampering, sabotage or other means of deliberate alteration. This provision applies to all BOP information resources while under the control of the contractor. As referenced in the BOP Policy Statement 1237.16, Information Security Programs, the contractor, while controlling BOP information assets, shall implement necessary safeguards, including administrative, physical, and personnel controls as outlined in said policy.

DOJ Order 0904

10. Personnel Security

Non-U.S. citizens are not authorized to access DOJ information systems or assist in the development, operation, management or maintenance of DOJ information systems, including providing information system support, unless a request for a waiver has been submitted by the Head of Component to and approved by, the DOJ CIO and the DSO allowing access or assistance by the non-U.S. citizen.

Component must:

- Ensure that individuals occupying positions of responsibility within the component (including third-party service providers) are trustworthy and meet security criteria established by DOJ for those positions;
- Ensure that only U.S. citizens are authorized to access DOJ information systems or assist in the development, operations, management, or maintenance of DOJ information systems, including providing information system support, unless for a waiver has been submitted by the Head of Component to, and approved by, the DOJ CIO and the DSO specifically allowing access or assistance by the non U.S. citizen.
- Ensure that DOJ information and information systems are protected during and after personnel actions, such as termination and transfer; and
- Employ formal sanctions for personnel failing to comply with DOJ security policy and procedures, in accordance with applicable laws and regulations.

The Department of Justice does not permit the use of non-US citizens in the performance of this contract or commitment for any position involves access to or development of any DOJ IT systems. By signing the contract document or beginning performance, the contractor agrees to this restriction.

DOJ RESIDENCY CONTRACTOR RESIDENCY REQUIREMENT

For three of the five years immediately prior to submission of an offer/bid/quote, or prior to performance under a contract or commitment, individuals, or contractor employees providing services must have: 1) legally resided in the United States (U.S.); 2) worked for the U.S. overseas in a Federal or military capacity; or 3) been a dependent of a Federal or military employee serving overseas. If the individual is not a U.S. citizen, they must be from a country allied with the U.S. The following website provides current information regarding allied countries: <http://www.opm.gov/employ/html/citizen.htm>. By signing this contract or commitment document, or by commencing performance, the contractor agrees to this restriction.

9.3 Systems Security

The work to be performed under this contract requires the handling of BOP data that originated within the Department, data that the contractor manages or acquires for the Department, and/or data that is acquired in order to perform the contract and concerns Department programs or personnel.

For all systems handling such data, the contractor shall comply with all security requirements applicable to Department of Justice systems, including but not limited to all Executive Branch system security requirements (e.g., requirements imposed by OMB and NIST,) DOJ IT Security Standards, and DOJ Order 2640.2E. The contractor shall provide DOJ access to and information regarding the contractor's systems when requested by the Department in connection with its efforts to ensure compliance with all such security requirements and shall otherwise cooperate with the Department in such efforts. DOJ access shall include independent validation testing of controls, system penetration testing by DOJ, FISMA data reviews, and access by the DOJ Office of the Inspector General for its reviews.

All operating systems and/or applications must be capable of auditing events and maintaining logs with sufficient information to be able to account for the actions of individual users and record system events and processes.

The use of contractor-owned laptops or other media storage devices to process or store data covered by this clause is prohibited until the contractor provides a letter to the contracting officer (CO) certifying the following requirements:

Laptops must employ encryption using a NIST Federal Information Processing Standard (FIPS) 140-2 approved product;

The contractor must develop and implement a process to ensure that security and other applications software is kept up to date;

Mobile computing devices will utilize antiviral software and a host-based firewall mechanism;

The contractor shall log all computer-readable data extracts from databases holding sensitive information and verify each extract including sensitive data has been erased within 90 days or its use is still required. All DOJ information is sensitive information unless designated as nonsensitive by the Department;

Contractor-owned removable media, such as removable hard drives, flash drives, and CDs containing DOJ data, shall not be removed from DOJ facilities unless encrypted using a NIST FIPS 1402 approved product;

When no longer needed, all removable media and laptop hard drives shall be processed (sanitized, degaussed, or destroyed) in accordance with security requirements applicable to DOJ;

Contracting firms shall keep an accurate inventory of devices used on DOJ contracts;

Rules of behavior must be signed by users. These rules shall address at a minimum: authorized and official use; prohibition against unauthorized users; and protection of sensitive data and personally identifiable information;

All DOJ data will be removed from contractor-owned laptops upon termination of contractor work. This removal must be accomplished in accordance with DOJ IT Security Standard requirements. Certification of data removal will be performed by the contractor's Project Manager and a letter confirming certification will be delivered to the CO within 15 days of termination of contractor work;

9.4 Data Security

By acceptance of, or performance on, this contract, the contractor agrees that with respect to the data identified in paragraph A, in the event of any actual or suspected breach of such data (i.e., loss of control, compromise, unauthorized disclosure, access for an unauthorized purpose, or other unauthorized access, whether physical or electronic), the contractor shall immediately (and in no event later than within one hour of discovery) report the breach to the DOJ CO and the contracting officer's representative (COR.)

If the data breach occurs outside of regular business hours and or neither the CO nor the COR can be reached, the contractor shall call the DOJ Computer Emergency Readiness Team (DOJCERT) at 1-866-US4-CERT (1-866-874-2378) within one hour of discovery of the breach. The contractor shall also notify the CO as soon as possible during regular business hours.

C. Personally Identifiable Information Notification Requirement

The contractor further certifies that it has a security policy in place that contains procedures to promptly notify any individual whose personally identifiable information (as defined by OMB) was, or is reasonably believed to have been, breached. Any notification shall be coordinated with the Department and shall not proceed until the Department has made a determination that notification would not impede a law enforcement investigation or

jeopardize national security. The method and content of any notification by the contractor shall be coordinated with, and be subject to the approval of, the Department. The contractor assumes full responsibility for taking corrective action consistent with the Department's Data Breach Notification Procedures, which may include offering credit monitoring when appropriate.

D. Pass-through of Security Requirements to Subcontractors

The requirements set forth in Paragraphs A through C above, apply to all subcontractors who perform work in connection with this contract. For each subcontractor, the contractor must certify that it has required the subcontractor to adhere to all such requirements. Any breach by a subcontractor of any of the provisions set forth in this clause will be attributed to the contractor.

10.0 Earned Value Management

The BOP will appoint a Contracting Officer's Representative (COR) for this project. The COR is responsible for receiving all deliverables, inspecting, and accepting the services provided for this requirement in accordance with the terms and conditions of this contract, providing direction to the contractor which clarifies the contract effort, fills in details, or otherwise serves to accomplish the contractual scope of work, evaluates performance, and certifies all invoices/vouchers for acceptance of the services furnished for payment prior to forwarding the original invoice to the payment office and a copy to the contracting officer.

The COR does not have the authority to alter the contractor's obligations under the contract action, direct changes that fall within the change clause, and/or modify any of the expressed terms, conditions, specifications, or costs of this agreement. If as a result of technical discussions, it is desirable to alter/change the contractual obligations or requirements, the Contracting Officer shall issue such changes in writing under signature.

The contractor shall provide a Project Manager. The Project Manager shall lead the overall execution of the activities in this statement of work, including providing project oversight and management of requirements defined in this statement of work. The Project Manager shall serve as the primary liaison between the Government and the contractor. Additionally, the Project Manager shall perform the following duties:

Ensure that:

- (1) All contractor staff understands and works toward deliverable objectives;
- (2) Tasks are staffed by appropriate, highly qualified personnel; and
- (3) All project management issues are communicated to and coordinated with the COR.

The contractor shall employ earned value management practices and reporting (ANSI/EIA Standard 748) to monitor and report to the Government progress against established resources and deliverable goals. Status reporting on deliverables shall provide accurate information concerning:

11.0 Inspection and Acceptance of Deliverables

The COR and/or BOP designated employee for each deliverable will have 15 workdays to review and accept deliverables under this statement of work.

12.0 Payment and Invoicing

The BOP will award a firm-fixed price task order for this statement of work. The contractor shall propose firm-fixed prices for each of the deliverables defined in Section 7.0, Deliverables, and Appendix A for this statement of work.

All invoices shall be prepared in accordance with FAR clause 52.212-4(g). The contractor shall invoice the Government only for completed deliverables. Invoices shall be sent to the address provided in block 18a of the SF 1449 Solicitation/Contract/Order for Commercial Items form. Payments will be made by electronic funds transfer (EFT) and in accordance with the Prompt Payment Act.

13.0 Project Management

The contractor shall provide the planning, direction, coordination and control necessary to accomplish all project phases. The contractor shall designate a Project Manager (key personnel) who is responsible for the cost, schedule, and technical performance of the contract and who will serve as the Contracting Officer's central point of contact with the government. The Project Manager is not required to be full-time.

Kick-Off Meeting

The contractor shall attend a kick-off meeting between BOP designated staff and the contractor team to discuss approach, policies, and procedure. The contractor shall provide a briefing on their technical approach for accomplishing results that meet the objectives of this task order to the Project Stakeholders.

Project Plan

The contractor shall provide a Project Plan that describes the technical approach, project personnel roles, organizational structure, available resources and management controls to be employed to meet the cost (monthly planned cost and hours for the period of performance), performance, schedule and milestones, communications, and quality requirements throughout the contract execution. The contractor must periodically update this Project Plan if there are any major changes in the work and/or schedule as bilaterally agreed to by the contractor and BOP. The contractor must deliver a draft Project Plan within five (5) days after the kick-off meeting. The final Project Plan shall be due within ten (10) days after FBOP review and comments.

Project Schedule

Within the Project Plan, the contractor shall provide a Project Schedule for all tasks assigned under this contract and in line with the agile development approach. The contractor Project Manager shall ensure that the Project Schedule is developed and presented to the BOP Project Manager/Contracting Officer Representative (COR) as part of the Project Plan. The Project Schedule shall identify all tasks, resources, and schedule. The Project Schedule shall become the schedule for the task and shall be maintained and updated weekly by the contractor for the duration of the contract/task to show progress completed. Tasks must have a short enough duration to update the project schedule on a weekly basis.

Progress Reports

The contractor shall provide written progress reports on a weekly and monthly basis for the duration of the project. These reports will be emailed to the COR and BOP Project Manager. The Weekly Progress Report shall cover all work completed during the previous week and shall present the work to be accomplished during the subsequent week. The Weekly Progress Report shall be between one (1) and three (3) pages in length. The Monthly Progress Report shall be a summary of the prior 30 days' work and the subsequent 30 days' work to be accomplished. The Monthly Progress Report shall be no longer than ten (10) pages in length. These reports shall also identify any problems that arose and a statement explaining how the problem was resolved. These reports shall also identify any problems that have arisen but have not been completely resolved and provide an explanation. Additionally, status updates shall be provided during bi-weekly project status meetings.

Meetings/Meeting Minutes

The contractor shall provide administrative and technical support for meetings as required. The contractor shall coordinate scheduling and meeting notifications if required. The contractor shall prepare and provide briefing slides, handouts, agendas, meeting minutes, and other supplementary materials as required. All virtual meetings between contractor personnel and BOP personnel must be conducted using the BOP's collaboration/meeting system(s).

Contractor Background Clearances

All contractors must comply with DOJ/BOP background clearance requirements before being permitted to do any work under a BOP contract. Contractors working remotely for the BOP will be issued contractor user accounts and PIV cards. Contractors will be required to use government furnished equipment (computers) to access the BOP network. To prevent loss of BOP data, all email communication between contractor personnel and BOP personnel must be conducted using BOP's email system.

14.0 Technical Standards for Acquisition of BOP IT Systems and Peripherals

DEFINITIONS

Information System: A discrete set of information resources organized for collection, processing, maintenance, use, sharing, dissemination, or disposition of information. (Note: Information systems also include specialized systems such as industrial/process controls systems, telephone switching and private branch exchange (PBX) systems, and environmental control systems.)

Peripheral Device: Any auxiliary device that connects to and works with a computer or information system in some way. Examples of peripherals are image scanners, tape drives, microphones, loudspeakers, and webcams.

1. INFORMATION SYSTEM REQUIREMENTS

1. APPLICABILITY

All information systems deployed within the BOP, or on behalf of BOP to include contractor built and operated on-prem, private cloud systems, or government cloud, must be developed to include support for the standards detailed in this section to the greatest extent possible regardless of whether the system is connected to the BOP's administrative network (BOPNet). All systems will be evaluated prior to acquisition and/or deployment to determine that each system supports the technical standards contained in this section. Approval to connect to BOPNet will not be granted to any system that cannot support these standards unless a waiver has been granted by the CIO.

Additionally, all systems must acquire an Authority to Operate (ATO) prior to use, and an Authority to Test (ATT) prior to system testing. Testing will not leverage live data (must use data created for the sole purpose of verifying functional capability and contain neither BOP nor BOP user information). A pilot, if needed, will also be performed without the use of live data. All the system environments, including development, test, quality assurance, integration, production, and any other environment related to the system, must reside within the authorization boundary.

2. OPERATING SYSTEMS, DATABASES, AND APPLICATIONS

1. OPERATING SYSTEMS AND DATABASES

All systems shall be developed to use BOP standard workstations, laptops, and servers with versions of operating systems and databases that are currently supported and will continue to be supported by the manufacturer/developer for at least three years after the BOP system goes live. Any system that requires operation on an operating system and/or database that is no longer supported or will be approaching its end-of-life or the end of extended support date before the contract expires, is prohibited from being installed unless a waiver is granted by the CIO.

All devices must have Defense Information Systems Agency (DISA) Security Technical Implementation Guide (STIG) Category I and Category II settings applied. Workstations and laptops with Windows operating systems must have DISA STIG settings applied for the versions of Windows currently in standard use in the FBOP. Servers, workstations, laptops, and other devices running non-Windows operating systems must be approved for use by the CIO prior to acquisition and must be the latest supported versions by the vendor. If a DISA STIG exists for any non-Windows operating system, the operating system must be configured in accordance with that DISA STIG.

Any system requiring on-premises installation of servers and/or server applications will require installation on BOP-provided virtual servers. All software, applications, and server appliances must receive approval for use from the BOP Information Technology and Data Division (ITDD) prior to installation.

2. APPLICATIONS

All systems on the BOP network shall be capable of using a BOP standard image for workstations. Systems shall be developed to minimize the installation of new applications directly onto workstations. Systems that require a client application be installed on workstations are strongly discouraged.

Web-based applications shall be installed on standard BOP servers running BOP-approved server operating systems and meet the following requirements:

- i. Support TLS (non-deprecated version);
- ii. Be browser-agnostic;
- iii. Not require browser plug-ins, helper objects, specific ActiveX controls, or Java dependencies on the client.

All applications must be able to operate with the latest version of any supporting applications or services required to run that application (i.e., Java, Apache, IIS, etc.).

3. IDENTIFICATION, AUTHENTICATION, AND AUTHORIZATION

To comply with Homeland Security Presidential Directive 12 (HSPD-12), all information systems must use a centralized directory for identification, authentication, and authorization to control, provision, and de-provision access to those systems. To connect to the FBOP network, all information systems must be capable of supporting Lightweight Directory Access Protocol (LDAP v3 or successor).

Systems that cannot support either a FBOP directory service or DOJ federated service and require the management of a separate credential store for identification, authentication, and authorization are prohibited. Each system user must be uniquely identified. Access to information is controlled using a "Least Privilege" role- or assignment-based methodology that provides the user with only the information and access required to perform his/her duties and nothing more. Systems must be capable of tiered-role privileges that distinguish between users and administrators and their authorized functions.

The federal government has implemented a Zero Trust security model to enforce least privilege per-request access decisions in information systems and services. Therefore, authentication to the system must be facilitated via the use of multi-factor authentication and access to the data controlled via role-based access.

4. ENCRYPTION

4.1. DATA AT REST

All information systems that store data must have the capability to encrypt the drives on which the data is stored using FIPS 140-2 compliant encryption. If the system cannot support encryption of system drives, it must be approved for use by the CIO prior to acquisition and use.

4.2. DATA IN MOTION

All information systems that transmit data over the BOP network must use protocols that encrypt data as it traverses the network. Information systems must support the most current version of secure protocols and encryption standards and must be capable of being configured to prevent the use of non-secure protocols.

4.3. PUBLIC FACING WEBSITES

Any information system that hosts a publicly accessible website and web services must only provide service through a secure connection (HTTPS) and must use HTTP Strict Transport Security (HSTS) to ensure this connection.

5. ENDPOINT SECURITY AND VULNERABILITY MANAGEMENT

All networked information systems shall be capable of being managed through an approved endpoint security and management application and be fully operational while being scanned for security vulnerabilities without disruption of service. All networked systems shall also be capable of being patched using a centrally managed patch management application.

Computer workstations, laptops, tablets, servers, and other computing devices using an operating system must employ anti-virus software protection. Anti-virus software and virus definition files must be updated with the most current versions and the anti-virus software must be configured to:

1. Begin protection when the devices are powered on;
2. Scan daily;
3. Check all files processed by the system in real time.

6. NETWORK STANDARDS AND PROTOCOLS

6.1. NETWORK STANDARDS AND APPROVED PROTOCOLS

Information systems must meet the following network standards to be deployed on the FBOP network:

1. Supports IPv4/v6 Dual Stack and provides full and equal functionality when utilizing IPv6 as when using IPv4;
2. Does not require or enable wireless of any type (Wi-Fi, Bluetooth, 3G/4G, etc.) unless an exception is granted by the CIO and is implemented per FBOP and DOJ guidelines;
3. All physical devices that make up the system must have a single network connection, only one IPv4 address, one Globally Unique IPv6 address, and not be capable of routing;
4. If internet accessible, can transmit traffic thru a proxy server to access the internet;
5. Does not require direct inbound connections from the public internet;
6. Does not allow out-of-band access (no modems, etc.);
7. Does not require media converters;
8. Does not directly connect to other IP networks;
9. Does not use IPv4 Multicast;
10. Cabling is IEEE Gigabit standard compliant;
11. Power over Ethernet (POE) devices are IEEE 802.3af compliant;
12. Cannot act (or is disabled from acting) as a DHCP server.

6.2. NON-SECURE PROTOCOLS

In accordance with current NIST standards, non-secure protocols must be disabled and not planned for use. The information system must have the capability of disabling any non-secure protocols including, but not limited to, the protocols listed below:

1. Telnet
2. FTP
3. SNMP v1/2
4. HTTP

7. CLOUD SERVICES

Any system that will connect to or be hosted in a non-BOP cloud service must use cloud service providers (CSP) that have been independently evaluated by an authorized FedRAMP 3PAO (Third Party Assessment Organization) and are FedRAMP-certified. The CSP must provide the most current System Security Plan (SSP), Control Implementation Summary (CIS), Customer Responsibility Matrix (CRM), Security Assessment Report (SAR), and list of any open Plans of Actions and Milestones (POAMs) to the BOP Chief Information Security Officer (CISO) for consideration. The CSP must receive an ATO from the BOP Authorizing Official (AO) prior to use.

7.1 CLOUD APPLICATIONS – REQUIREMENTS FOR COTS AND CUSTOM DEVELOPED

Contractors must develop or provide administration and user guides for applications, whether the application is custom developed for the BOP or is a Commercial Off the Shelf (COTS) product.

All applications must adhere to Section 508 accessibility standards.

7.2 CLOUD APPLICATIONS – CUSTOM DEVELOPED

The BOP owns any and all source code generated for applications custom developed for the BOP. The source code for any application custom developed for the BOP must be delivered to the BOP before the contract expires.

- Contractors shall use an Agile development strategy (or similar strategy) to enable rapid development with routine opportunities for stakeholders to review progress and provide feedback during the development process.
- Applications shall adhere to usability principles, plain language, and industry best practices.
- Applications shall interface with the BOP's IdP using SAML2.0 or OAuth 2.0 to appropriately authenticate users and protect sensitive resources.
- Application data shall be made available via webservices that are built using REST APIs, with endpoints appropriately protected.
- Applications intended for deployment in the BOP's cloud environment shall either be hosted in AWS GovCloud West or AWS GovCloud East, depending on the FISMA classification of the information contained in the system.
- Contractors shall identify exact cloud services and resources (i.e., Lambda, RDS types, EC2 instance types, etc.) that will be required to build the system and use the AWS cost estimation tool to provide a breakdown of the anticipated system cost.
- Contractors shall make necessary changes to the application, configuration, or cloud infrastructure/services script (i.e., IaC) if required by the BOP cloud team.
- Contractors shall create CloudFormation scripts that will be used to build the Virtual Private Clouds (VPC) and infrastructure needed, and make necessary changes as identified by the FBOP cloud team.
-

Any exceptions to the above statements must be reviewed and approved by BOP IT Leadership, and under no circumstances will any deviation from these statements that adversely affects the security of the BOP IT environment or data be permitted.

8. MEDICAL SYSTEMS

Medical systems must comply with standards published by the Office of the National Coordinator for Health Information Technology (ONC) in regard to data access, storage, and reporting. Medical software/systems must be Health Insurance Portability and Accountability Act (HIPAA) compliant. The contractor shall provide a HIPAA compliance plan and designate a compliance officer with the required extensive background/training to satisfy this requirement. As part of HIPAA compliance, covered entities must:

- Ensure the confidentiality, integrity, and availability of all e-PHI the contractor creates, receives, maintains or transmits;
- Identify and protect against reasonably anticipated threats to the security or integrity of the information;
- Protect against reasonably anticipated, impermissible uses or disclosures; and
- Ensure compliance by the contractor's workforce.

9. MOBILE APPLICATIONS

Mobile applications must be designed using HTML5 or operate natively on a version of the Android operating system currently being supported by industry with security patches.

10. PERIPHERAL REQUIREMENTS

10.1 LOCALLY ATTACHED PERIPHERALS

Peripherals that are locally attached to standard BOP workstations must:

1. Not be shared on the network;
2. Not require software to operate that requires access to the internet or other network resources;
3. Not require software to operate that requires older versions of software to operate such as Java;
4. Not broadcast wireless signals (i.e., Bluetooth, WiFi, etc.);
5. Not require a change to the workstation local security policy to operate.

10.1.1. LOCALLY ATTACHED PRINTERS AND SCANNERS

Locally attached printers and scanners must have 64-bit drivers and cannot be shared to workstations other than the workstation to which it is directly connected.

10.2. NETWORKED-ATTACHED PERIPHERALS

Peripherals that must connect directly to the BOP network shall be part of a larger system or sub-system authorized to operate on that network. Each system or sub-system must provide controls to the peripherals attached to the network that comply with the system standards detailed above or provide mitigating controls for peripherals that cannot meet a system standard.

10.2.1. MULTI-FUNCTION DEVICES AND NETWORKED PRINTERS

All multi-function devices (MFD) and networked printers must be capable of being configured in accordance with the Multifunction Device and Network Printers DISA STIG.

MFDs must be capable of supporting PIV authentication either directly or via a peripheral attachment/software but are not required to use PIV authentication at this time.

11. SECURITY ASSESSMENT AND AUTHORIZATION COMPLIANCE

The BOP will conduct an Assessment & Authorization (A&A) of the system before the Chief Information Officer's office issues an Authority to Operate (ATO) on the system.

Government project officers are responsible for ensuring their contractor-hosted or cloud-hosted applications are authorized to operate (ATO) in accordance with the Federal Information Security Modernization Act of 2014 (FISMA). This activity includes all planning, testing, and continuous monitoring activities associated with the system's lifecycle. Most importantly, this means that the vendor is responsible for securing the resources to conduct required security testing, which for moderate or higher impact systems means using an independent third-party assessor qualified to conduct FISMA/FedRAMP audits. The BOP will not develop required FISMA/FedRAMP security documentation (except for assisting with the FIPS-199, e-Authentication, and Privacy Impact Assessment), or conduct any of the security testing for applications that are operated exclusively at contractor locations or hosted in the cloud. The extent of BOP's support for exclusively contractor- and cloud-hosted systems is advisory only.

A&A is the methodology by which an organization establishes and then demonstrates a sound, risk-based security posture for a specific system. The A&A process establishes the extent to which a particular design and implementation meet a set of specified security requirements defined by the organization, government guidelines, and federal mandates into a formal authorization package. This authorization package is reviewed by the Authorizing Official (AO) and a formal declaration of an information system accreditation is either granted as an Authorization to Operate (ATO) or ATO with conditions or outright denial of authorization to operate. For more information about A&A requirements for federal IT systems, please see NIST SP 800-37 Rev 2 (<https://csrc.nist.gov/pubs/sp/800/37/r2/final>).

When this assessment is conducted, the vendor may be required to answer questions, to participate in the A&A process and potentially implement any information security changes necessary to facilitate receiving an ATO for this system. The system is required to meet or exceed specific and relevant security requirements identified and detailed in the Security and Privacy Requirements documentation.

Where a follow-up action against a person or the BOP after an incident involves legal action (either civil or criminal), the system shall ensure that evidence can be collected, retained, and presented to conform to the rules for evidence in accordance with Federal rules of civil or criminal procedures.

The system and any/all electronic and information technology procured through this effort must be compliant with 29 U.S.C § 794d - Electronic and information technology (Section 508 compliance Amendment to the Rehabilitation Act of 1973) and the applicable accessibility standards at 36 CFR 1194. 36 CFR 1194 implements Section 508 of the Rehabilitation Act of 1973, as amended, and is viewable at <https://www.section508.gov/>. Standards applicable to this requirement include Functional Performance criteria 1194.31 and Information, Documentation, and Support 1194.41.

Because of the above requirements, the contractor must include Information Systems Security Officer (ISSO) resources as part of the proposal to assist in the development of documentation for the ATO process. Such personnel should be experienced and familiar with writing control implementation statements so that security controls can be appropriately and promptly assessed. The length of the ATO process is dependent on the outcome of the quantity and quality of resources proposed for the solution.

12. PRIVACY AND RECORDS MANAGEMENT

All systems must be evaluated prior to ATT or ATO for privacy and records management requirements. An Initial Privacy Assessment (IPA) must be completed and if BOP Privacy and Records Management Branch, and DOJ Office of Privacy and Civil Liberties (OPCL) determines that the system collects, processes, stores or disseminates personally identifiable information (PII), a Privacy Impact Assessment (PIA) must be done to evaluate the impact on the confidentiality, integrity, and availability of the system data. If required, the BOP Office of General Counsel (OGC) will prepare a System of Records Notice (SORN) to be published in the federal register prior to system's deployment. All systems must complete a Records and Information Management Certification (RIMCert) evaluation regardless of Personally Identifiable Information (PII) status.

13. SYSTEM INTERCONNECTIONS

DOJ requires that Components must identify all system interconnections, both external and internal to DOJ. A system interconnection is defined as the direct connection of two or more IT systems for the purpose of sharing data and other information resources. All interconnections from one information system to another system outside of the respective accreditation boundaries must have an approved Interconnection Security Agreement (ISA), and optionally a Memorandum of Understanding/Agreements (MOU/A). Both parties must mutually agree on terms and conditions and define expiration requirements or timelines. The agreements define how security will be maintained for the interconnection during its operation. Information systems are only permitted to interconnect with systems that have undergone a system authorization and have a current Authorization to Operate (ATO). If the Authorizing Official (AO) is the same for both interconnecting systems, an ISA or MOU/A is not required.